

The Converged Infrastructure Forensics Model (CIFM)

Author: Kerry Hazelton ("Professor Kilroy")

Version 1.5RC — June 2026

Release Candidate — Shadow Systems, Shadow AI, reconstruction debt

Abstract

Modern cyber incidents increasingly occur across interconnected ecosystems spanning cloud platforms, telecommunications networks, edge systems, IoT/IIoT devices, and operational technology. Traditional host-centric digital forensic methodologies are insufficient for reconstructing adversary activity in these distributed, identity-driven environments.

This paper introduces the **Converged Infrastructure Forensics Model (CIFM)**, an investigative framework for reconstructing adversary activity across converged infrastructure ecosystems using identity-centric analysis, distributed telemetry, and human-validated reasoning. CIFM synthesizes previously independent domains into a unified investigative model and introduces key contributions, including a normalized evidence representation (Unified Evidence Manifest), a visibility and trust boundary assessment model, and a constrained human–AI hybrid analysis approach.

CIFM defines a distinct layer within the cybersecurity ecosystem—investigative reconstruction across converged infrastructure environments—complementing existing adversary behavior and attribution frameworks by providing the structured methodology required to discover, correlate, and reconstruct the evidence upon which they depend.

1. Introduction

Infrastructure environments that were once clearly separated—enterprise IT systems, telecommunications networks, cloud platforms, industrial control systems, and Internet-of-Things ecosystems—have become deeply interconnected through shared identity systems and control-plane mechanisms (the APIs and identity-driven mechanisms used to manage infrastructure). This convergence expands operational capability but fundamentally changes how cyber incidents must be investigated. In modern environments, adversaries routinely exploit identity systems, automation pipelines, and distributed infrastructure to move across domains where evidence is fragmented across cloud logs, network telemetry, and operational systems.

Traditional digital forensic methodologies evolved in host-centric environments where evidence resided on local systems. In converged infrastructure ecosystems, however, critical evidence is distributed across identity providers, control-plane logs, network flows, and industrial telemetry systems. These conditions create a gap: existing forensic models do not provide a unified methodology for reconstructing adversary activity across interconnected infrastructure domains. For example, an

investigation scoped only to cloud logs may miss identity-driven activity occurring through network infrastructure or edge systems (expanded in §3).

CIFM addresses this gap by providing a unified, infrastructure-centric investigative model that emphasizes measurable visibility, normalized evidence representation, iterative reconstruction, and human-in-the-loop validation. This model is an investigative reconstruction framework applied after or alongside detection; it does not provide detection or monitoring capabilities.

2. Origins of the Model

CIFM emerged from nearly a decade of applied teaching, incident analysis, and practitioner feedback. The model was developed and refined through hands-on instruction in network analysis and cloud forensics at U.S. security conferences (Security BSides, HOU.SEC.CON, DEF CON) and through operational engagements between 2016 and 2025. That lineage matters: CIFM synthesizes classroom exercises, red/blue team reconstructions, and real-world incident postmortems into a practical investigative doctrine. Establishing this provenance clarifies CIFM's intent and situates it among prior forensic models and operational playbooks.

3. Why Existing Models Fail in Converged Environments

Existing forensic models struggle in converged environments due to:

- **Domain isolation assumptions:** Traditional models assume evidence resides in a single system or domain.
- **Insufficient identity analysis:** Modern attacks often pivot through identity providers and automation pipelines rather than only endpoints.
- **Telemetry heterogeneity:** Logs and event models differ across cloud, OT, IoT, and telecom systems.
- **Linear workflow assumptions:** Investigations are rarely linear; new telemetry often forces re-examination of prior hypotheses.
- **Provider opacity:** Cloud and SaaS platforms may limit access to underlying artifacts or provide only partial telemetry (e.g., restricted SaaS audit logs or limited cloud provider retention tiers).

CIFM addresses these limitations by explicitly integrating architectural context, identity analysis, telemetry normalization, hybrid intelligence safeguards, and explicit human validation.

4. Formal Definitions

4.1 Converged Infrastructure

Converged infrastructure is an operational ecosystem in which cloud platforms, telecommunications networks, edge systems, IoT/IIoT devices, and OT/ICS environments are interconnected through shared identity systems, APIs, automation pipelines, and control-plane mechanisms. These domains

exchange telemetry, trust signals, and operational commands, creating a unified but heterogeneous investigative surface.

4.2 CIFM

CIFM (Converged Infrastructure Forensics Model) is a layered investigative framework for reconstructing cyber incidents across converged infrastructure ecosystems. CIFM correlates identity-centric control-plane activity with distributed telemetry under human-validated reasoning constraints. The model separates evidence discovery and reconstruction from interpretation and attribution.

CIFM Layers

1. **Infrastructure Ecosystems** — domain mapping and trust boundaries.
2. **Identity & Control Plane** — authentication, authorization, API activity.
3. **Telemetry Fabric** — normalized event streams across domains.
4. **Hybrid Intelligence** — machine assistance for correlation and hypothesis generation.
5. **Human Investigative Authority** — validation, interpretation, and narrative reconstruction.

The CIFM can be visualized as a layered stack, shown below:

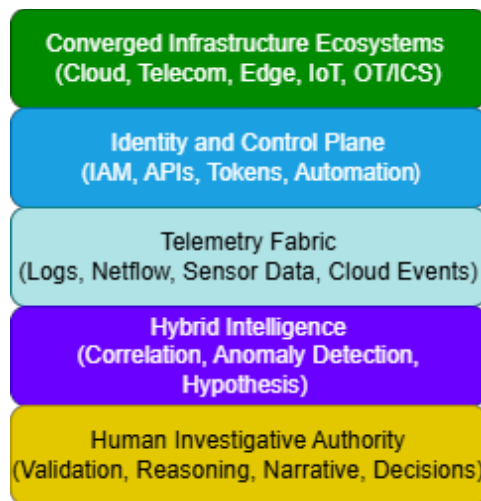


Figure 1. CIFM Layered Architecture.

5. Claim of Contribution

This paper introduces the Converged Infrastructure Forensics Model (CIFM), an investigative framework designed to address the limitations of traditional host-centric digital forensics in modern, converged infrastructure environments. While individual components of CIFM have precedent in prior work, no existing model integrates identity-centric analysis, cross-domain telemetry normalization, and iterative reconstruction into a unified investigative workflow for converged infrastructure environments.

Existing forensic methodologies and research efforts have made significant contributions within specific domains, including cloud forensics, IoT and IIoT investigations, operational technology (OT/ICS) security, and telemetry-centric detection and response systems. However, these approaches typically address individual environments or specific phases of the incident lifecycle rather than providing a unified model for reconstructing adversary activity across interconnected infrastructure domains.

CIFM contributes to the field by synthesizing these previously independent areas into a single, structured investigative model. It introduces four primary structural contributions (UEM, HITL tiers, iterative workflow, visibility matrix) while formalizing and synthesizing several existing investigative concepts (identity pivot, telemetry, investigative framework, forensic readiness):

- **Unified Evidence Manifest (UEM).** CIFM introduces a normalized, domain-agnostic evidence schema designed to resolve telemetry heterogeneity and support reproducible, machine-assisted cross-domain correlation.
- **Human-in-the-Loop (HITL) Validation Tiers.** CIFM defines a tiered validation model that explicitly constrains AI assistance and preserves human investigative authority at each phase of the workflow.
- **Iterative, non-linear workflow.** CIFM explicitly models the non-linear nature of real investigations, distinguishing it from sequential forensic process models.
- **Visibility & Trust Boundary Matrix.** CIFM introduces a structured pre-investigation assessment tool for quantifying telemetry availability and investigative confidence across domains before reconstruction begins.
- **Identity as the investigative pivot.** CIFM formally establishes identity and control-plane activity as the primary investigative anchor in converged environments, reflecting the reality that modern adversaries frequently pivot through identity systems rather than endpoints.
- **Telemetry as primary evidence.** CIFM prioritizes distributed telemetry as the primary source of evidentiary data in environments where host artifacts are incomplete or absent.
- **Unified investigative framework for converged infrastructure.** CIFM formally integrates cloud, telecommunications, edge, IoT/IIoT, and OT/ICS domains into a single, operationally focused investigative methodology—treating them as components of a unified investigative surface rather than isolated domains.
- **Forensic readiness as an investigative dependency.** CIFM formally establishes that investigative capability in converged environments cannot be reliably created once an investigation is underway—it must be designed and maintained before incidents occur.

In doing so, CIFM defines a distinct layer within the cybersecurity ecosystem: investigative reconstruction across converged infrastructure environments. This role is complementary to existing adversary behavior frameworks and knowledge bases (e.g. MITRE ATT&CK), as well as analytical models such as the Diamond Model and Cyber Kill Chain; and attribution methodologies such as

FACT (structured attribution methodology used in threat intelligence analysis). The CIFM does not seek to replace them. Rather, it provides the structured methodology required to discover, correlate, and reconstruct the evidence upon which those frameworks depend.

6. Related Work and Prior Art

CIFM builds on multiple research and operational areas:

- **Cloud forensics:** provider logs, API activity, virtualization artifacts (Ruan et al., 2011).
- **IoT/IIoT forensics:** distributed evidence, constrained devices, edge gateways (Oriwoh et al., 2013; Stoyanova et al., 2020).
- **OT/ICS security:** industrial protocols, safety constraints, IT/OT convergence (CISA & ICS-CERT, 2016).
- **Forensics and compliance auditing for critical infrastructure:** Henriques et al. (2023) propose a Forensics and Compliance Auditing (FCA) framework for IACS environments using a cloud-native architecture. Their work addresses the evidence-collection infrastructure that CIFM's forensic-by-design principle depends on—specifically, persisting forensic-quality evidence from distributed IACS environments at scale. The two frameworks are complementary: FCA addresses continuous evidence collection and compliance auditing within IACS; CIFM operates as the investigative reconstruction layer above such systems. Where FCA's primary sources are network/host probes and SCADA logs, CIFM explicitly anchors reconstruction on identity and control-plane pivots through cloud orchestration—a surface FCA does not address.
- **Telemetry-centric operations:** Recent academic work describes the evolution from SIEM-centric architectures toward telemetry-first security operations and Extended Detection and Response (XDR) models that unify cross-layer telemetry for correlation and investigation (Alshamrani et al., 2022).
- **Human-AI hybrid analysis:** Research on human–AI collaboration emphasizes human-in-the-loop governance, trust calibration, and reproducibility as essential requirements for safe and auditable AI-assisted security analysis (Kamar, 2016).
- **AI-enabled systems as evidence sources:** model versioning, weights metadata, inference logs, and adversarial ML considerations. (emerging area; limited formal literature) Appendix B provides operational guidance for applying CIFM to AI-driven operational incidents.
- **Observability and Telemetry Standards.** OpenTelemetry offers a vendor-neutral language—traces, spans, and context propagation—for describing telemetry in distributed and AI-connected systems. CIFM does not adopt observability as forensic doctrine. Instead, CIFM treats observability outputs as raw evidence sources whose value must be earned through documented preservation, provenance, collection continuity, and corroboration against authoritative systems of record.

This literature provides conceptual building blocks; CIFM unifies them into an operationally focused investigative model. CIFM is conceptually aligned with Zero Trust Architecture in its emphasis on

identity, telemetry, and continuous visibility. However, while Zero Trust focuses on access control and prevention, CIFM focuses on reconstructing adversary activity across those same environments.

7. Motivating Incident Scenario

Public reporting on campaigns such as Volt Typhoon illustrates the operational realities that motivate CIFM: adversaries leveraging identity compromise, legitimate administrative tooling, and living-off-the-land techniques to persist and move laterally across cloud, telecom, and OT environments. Consider a representative sequence observed across recent campaigns:

1. **Initial compromise:** Phished credentials for a cloud identity provider are used to obtain temporary tokens.
2. **Control-plane misuse:** The adversary provisions ephemeral compute and automation jobs, using legitimate APIs to avoid endpoint artifacts.
3. **Telemetry pivoting:** Activity appears in cloud audit logs and telecom gateway flows, but not on local OT endpoints.
4. **Edge/OT targeting:** The adversary attempts to reach OT gateways via edge proxies, using legitimate service accounts and scheduled jobs.
5. **Detection and reconstruction challenge:** Host artifacts are sparse; evidence is distributed across provider logs, network flows, and OT sensor telemetry.

This scenario demonstrates why CIFM's identity-first, telemetry-centric, and iterative approach is necessary: investigators must measure visibility, normalize heterogeneous evidence, and iterate between telemetry and hypothesis until a defensible narrative emerges.

8. CIFM Design Principles

8.1 Infrastructure Context First

- Investigations begin with understanding the environment's architecture, trust boundaries, and inter-dependencies.

8.2 Identity as the Investigative Pivot

- Authentication, authorization, and API control activity often reveal the earliest and most meaningful traces of adversary movement, where available and attributable within legal and operational constraints.

8.3 Telemetry as Primary Evidence

- In converged environments, evidence frequently resides in logs, network flows, sensor telemetry, and control-plane events rather than in local disk artifacts.

8.4 Correlation Across Domains

- Meaningful reconstruction often depends on correlating evidence across cloud, telecom, edge, IoT, enterprise, and OT domains.

8.5 Hybrid Intelligence Analysis

- Machine assistance can accelerate triage and correlation, but it must remain subordinate to human validation.

8.6 Human Sovereignty in Investigative Conclusions

- Humans retain responsibility for validation, interpretation, and final narrative reconstruction.

8.7 Forensic-by-Design Infrastructure

- Organizations should design environments to preserve visibility, retention, and investigative traceability before incidents occur. These capabilities cannot be reliably established once an investigation is underway.

8.8 Shadow Environment Awareness

- Investigations must account for the possibility that the inventoried infrastructure represents a floor, not a ceiling, of what requires forensic attention. Ungoverned systems, untracked credentials, undocumented AI integrations, and orphaned automated processes may exist within and adjacent to the investigative surface without appearing in official asset records, architecture diagrams, or telemetry configurations. CIFM treats the unverified absence of such systems as a visibility condition requiring explicit investigative assessment, not a confirmed clean state.

9. CIFM Investigation Workflow

The following phases represent a default investigative sequence; in practice, CIFM is iterative, and phases may repeat or occur in parallel. Investigations may begin at any phase depending on the triggering event (e.g., identity alert, network anomaly, OT event), and progress non-linearly. While CIFM is designed for full cross-domain investigations, organizations rarely begin with complete visibility. For this reason, Section 9.8 introduces a Minimum Viable CIFM Implementation (MVI)—an illustrative, low-friction starting point that allows teams to apply the model immediately and expand coverage as visibility improves.

9.1 Phase 1 – Infrastructure Context Assessment

Document architecture, trust boundaries, identity providers, telemetry pipelines, and cross-domain connectivity.

9.1.1 Visibility & Trust Boundary Matrix

- **Purpose:** Quantify telemetry visibility and trust across domains to establish investigative confidence.
- **Domains assessed:** Cloud, Telecom, IoT/IIoT, OT/ICS, Edge Computing
- **Visibility categories:** *Visible* (full log access), *Partially visible* (limited/provider-controlled logs), *Dark* (no telemetry).

- **Outputs:** A domain-by-domain visibility table with confidence weights and notes on legal/contractual constraints.

This matrix establishes investigative confidence and grid density. See Section 14 for guidance on representing ephemeral workload domains within the Visibility & Trust Boundary Matrix.

Infrastructure Domain	Control Plane / Identity	Network Telemetry	Endpoint / Host	Operational / Sensor	Visibility	Confidence Weight	Notes
Cloud (AWS/Azure)	IAM/Audit Logs (e.g., CloudTrail)	VPC Flow Logs / Traffic Mirroring	Cloud-init / Serverless Logs	API-driven automation records	Visible	0.9	Full CloudTrail, API logs retained 90 days
Telecommunications	Auth/Provisioning Logs	Netflow / Signaling Data	Edge Gateway OS	Physical Layer Alarms	Partially visible	0.6	Flow records available; provider retains deep packet logs
IoT / IIoT	Device Registry / MQTT Auth	Gateway Traffic Analysis	Firmware / Device Memory	Sensor Threshold Violations	Dark	0.2	Device logs ephemeral; vendor access required
Operational Tech	Engineering Workstation Logs	Industrial Protocol Dissection	PLC Logic States	HMI / SCADA Event Logs	Partially visible	0.4	PLC event logs limited; historian snapshots available
Edge Computing	Access Tokens / API Keys	Distributed Packet Capture	Local Cache Logs	Environmental Telemetry	Partially visible	0.5	Gateway logs retained; device telemetry limited

Figure 2. Visibility and Trust Boundary Matrix.

Shadow Systems as Visibility Gap Contributors

The Dark visibility category within the Visibility & Trust Boundary Matrix encompasses not only domains where telemetry collection was configured but is unavailable, but also systems and integrations whose existence was not known to the organization at the time of collection. Shadow IT deployments, ungoverned SaaS integrations, undocumented API connections, and AI tool deployments outside formal procurement create investigative surfaces that may not appear in standard architecture documentation or telemetry coverage maps.

Investigators encountering unexplained activity patterns, NHI credentials with no documented owner, or API calls to unrecognized endpoints should treat these as potential indicators of shadow system presence. Such indicators should be documented as candidate Dark domains pending further investigation, rather than treated as noise or excluded from the evidence matrix. The absence of a system from official records is not evidence that the system does not exist; it is a gap in organizational visibility that requires resolution.

9.2 Phase 2 – Identity & Control-Plane Analysis

- Review authentication logs, IAM activity, API calls, automation events, and service account usage.
- Map identity relationships, delegation chains, and temporary credential issuance.
- Produce identity pivot timelines and candidate actor lists with documented confidence assessments.

Non-Human Identity (NHI) in Identity Analysis

Non-human identity (NHI) — API keys, OAuth tokens, service accounts, CI/CD pipeline credentials, machine-to-machine certificates, and automation credentials that authenticate as non-human entities — warrants specific investigative attention within identity and control-plane analysis. In many cloud-connected and OT-adjacent environments, non-human identities may substantially exceed human identities. In environments where shadow systems are present, actual NHI counts may exceed organizationally documented counts by an unknown margin.

NHI credentials are architecturally distinct from human identities: they do not appear in employee directories, do not carry organizational ownership assignments by default, and generate behavioral

patterns that are expected to be non-human, repetitive, and asynchronous. An adversary operating through a compromised NHI inherits that normalcy entirely, making adversary activity through NHI channels difficult to distinguish from expected machine behavior without baseline comparison and behavioral reconstruction.

During identity analysis, investigators should assess each discovered NHI credential against three questions:

Ownership: Does this credential have a documented owner with current organizational authority to verify its purpose? Orphaned credentials — those whose creating or responsible individual has departed or changed roles — should be treated as elevated-uncertainty sources pending ownership verification.

Purpose and scope: Does the credential's current permission scope reflect its original authorized purpose, or has scope expanded through API, SaaS, or infrastructure changes without re-authorization? This is blast radius assessment applied to identity analysis.

Provenance: Was this credential created through an official governance process, or does its creation record suggest an ungoverned integration? Ungoverned NHI is a potential shadow system indicator.

9.3 Phase 3 – Telemetry Fabric Correlation

Correlate cloud logs, network flows, endpoint data, sensor telemetry, and control-plane events.

9.3.1 Unified Evidence Manifest (UEM)

- **Purpose:** Normalize heterogeneous event sources into a single, chronologically stable stream for correlation and machine-assisted analysis.
- **Caveat:** Normalization decisions are inherently interpretive and may influence reconstruction outcomes; investigators must document mapping logic and assumptions. Where possible, hashes should reference original artifacts; hashing normalized records must be explicitly flagged. Normalized UEM records are analytical constructs and must not replace original artifacts as primary evidence; they exist to support correlation and reconstruction while preserving traceability to source data.
- **Core UEM fields:**
 - **Event Time (UTC)** — canonical timestamp.
 - **Infrastructure Domain** — Cloud/Telecom/Edge/IoT/OT.
 - **CIFM Layer** — Identity, Control-Plane, Network, Endpoint, Sensor.
 - **Actor Identity** — user/service principal (hashed if required).
 - **Action Verb** — e.g., Authenticate, CreateInstance, WritePLC, OpenPort.
 - **Object Target** — resource identifier.
 - **Outcome** — Success/Failure/Partial.
 - **Evidence Hash** — cryptographic hash of the original artifact or canonicalized record.
- **Ephemeral Resource / Workload UEM Extension (Optional):** Additional fields for ephemeral workload investigations. See Section 14 for full guidance.

- **AI-Driven Operational Incident UEM Extension (Optional):** Additional fields for AI-linked investigations, including prompts/inputs, model outputs, tool invocations, retrieval context, delegated authority, approval state, downstream effects, and reproducibility status. See Appendix B-2 for full guidance.
 - **Resource Type:** container | pod | task | function | job | ci_runner | autoscaled_instance | other
 - **Orchestrator:** Kubernetes | ECS | Fargate | Lambda | Cloud Run | Azure Container Apps | GitHub Actions | GitLab CI | Nomad | other
 - **Resource Identifiers:**
 - **Parent Resource Identifier:** Cluster | Namespace | Account | Project | Node | Host
 - **Environment Context:** Prod | Non-Prod | Staging | Dev | Other
 - **Artifact Identifier:** Workload ID | Container/Task/Pod ID | Image Name | Image Digest | Build Hash | Registry Source | Deployment Source | Deployment Version/Commit
 - **Principal Identity:** Assumed Role | Service Account | IAM Role | Token Source | Creator
 - **Deployment Source:** CI/CD pipeline | manifest | job spec | task definition | controller | unknown
 - **Declared State Source:** manifest | compose | job spec | task definition | controller | pipeline definition | none | unknown
 - **Observed State Source:** runtime logs | node telemetry | registry records | network telemetry | identity telemetry | runtime sensor | other
 - **Initiating Mechanism:** parent container | privileged workload | job runner | CI/CD pipeline | entrypoint script | API call | container socket access | automation framework | unknown
 - **Parent Workload / Job:** identifier or unknown
 - **Origin Chain Confidence:** high | medium | low | unknown
 - Created Time | Start Time | Terminated Time | Exit Code or Reason
 - **Runtime Telemetry Sources:** audit logs, flow logs, stdout/stderr, runtime sensors
 - **Preservation Status:** imaged | logs only | metadata only | unavailable
 - **Visibility Impact:** qualitative or matrix-derived
 - **Confidence Impact**
 - **Analyst Notes**
- **Rationale:** UEM resolves heterogeneity, supports reproducible timelines, and provides a clean input for hybrid intelligence.
- **Example UEM entry (sanitized):** 2026-03-16T14:12:03Z | Cloud | Identity | user:alice@example.com | Authenticate | idp/session/1234 | Success | sha256:...
- **Example (AWS Provider Mapping):**
In a cloud-only investigation, common AWS telemetry sources map cleanly into UEM fields:
- **CloudTrail** → *Identity / Control-Plane*
 - Authentication events, API calls, temporary credential issuance

- Maps to: *Event Time, Infrastructure Domain, Actor Identity, Action Verb, Object Target, Outcome*
- **VPC Flow Logs** → *Network Telemetry*
 - Source/destination pairs, ports, protocols, accept/deny decisions
 - Maps to: *Event Time, Infrastructure Domain, Action Verb (e.g., Connect/Accept/Reject), Object Target, Outcome*
- **CloudWatch / Lambda Execution Logs** → *Execution / Endpoint-Equivalent*
 - Function invocation, runtime behavior, error traces
 - Maps to: *Event Time, CIFM Layer (Endpoint/Execution), Actor Identity (service role), Action Verb, Outcome*

These mappings demonstrate how heterogeneous cloud telemetry can be normalized into UEM entries to support cross-domain correlation. Equivalent mappings exist for Azure and GCP; standardized multi-cloud mappings are identified as future work.

Teams beginning with limited telemetry can still apply CIFM’s correlation workflow; Section 9.8 outlines a Minimum Viable CIFM Implementation (MVI) that demonstrates how to operationalize these steps within a single domain.

9.3.2 Operational Observability and AI-Agent Telemetry

AI-agent activity may be exposed through vendor-native audit logs, OpenTelemetry-compatible pipelines, runtime instrumentation, model or framework logs, provider audit trails, orchestration records, endpoint telemetry, source-control events, CI/CD records, network telemetry, and downstream system-of-record logs. CIFM treats these as **operational observability artifacts** until they are validated, correlated, bounded by visibility constraints, and weighted by provenance and evidentiary integrity.

OpenTelemetry may provide a vendor-neutral observability substrate for AI-agent activity where supported. Core concepts—traces, spans, logs, metrics, and context propagation—can help link prompts, sessions, tool invocations, delegated identities, workflow steps, API calls, and downstream effects. These signals assist reconstruction, but they do not establish completeness, causality, intent, non-repudiation, or chain of custody.

OpenTelemetry generative-AI and agent/framework semantic conventions should be used where supported. Investigators must document the convention version, instrumentation scope, implementation library, and any experimental elements in use. Where no standard field exists, implementation-specific attributes may be mapped into UEM extension fields, but the mapping must be explicitly documented as an interpretive normalization decision.

9.3.2.1 Observability vs. Reconstruction

Operational observability answers what a system reported from a particular vantage point. Forensic reconstruction asks what happened, how it is known, what remains unproven, what visibility gaps constrain the claim, and what confidence is justified. A trace is not a narrative. A span is not proof of effect. A prompt or session identifier is not proof of intent. A tool result is not proof of downstream action. A collector record is not proof of completeness. Absence of telemetry is not proof of absence.

CIFM therefore requires AI-agent telemetry to be evaluated through the same constraints applied to other converged-infrastructure evidence: source provenance, timestamp provenance, collection continuity, transformation history, corroboration, visibility gaps, and human validation. Telemetry-derived events may enter a candidate timeline, but only validated events should appear in the final narrative without qualification.

9.3.2.2 AI-Agent Telemetry Taxonomy

The following taxonomy defines how AI-agent telemetry artifact types are treated within CIFM reconstruction practice. These definitions govern how artifacts are classified and what evidentiary claims they may support.

Agent trace. A trace or parent/child span chain representing reported AI-agent activity, such as model interaction, retrieval, workflow execution, or tool invocation. Useful for behavioral reconstruction and candidate sequencing. Not self-authenticating and not sufficient to prove completeness or downstream effect.

Tool execution record. A log event, span, span event, or framework record indicating that a tool, connector, API, shell, workflow step, or external system was invoked. May support primary evidentiary claims only when collection configuration, timestamp provenance, identity context, and downstream effect are corroborated.

System log. An operating system, shell, endpoint, application, cloud, identity, CI/CD, source-control, or business-system record outside the AI-agent telemetry pipeline. Provides independent corroboration and may elevate a reported tool execution into a validated event.

Collector/backend record. A record produced by the telemetry collection, processing, routing, or storage layer. Documents how telemetry reached the investigator and what may have been sampled, redacted, transformed, dropped, or enriched. In CIFM, the collector configuration and processor pipeline are evidence environment artifacts, not neutral conduits.

Validated event. A UEM entry supported by documented provenance, trusted or cross-checked timestamping, at least one independent corroborating source where available, and human validation. Suitable for formal narrative timelines subject to stated confidence and visibility constraints.

9.3.2.3 Collector and Pipeline Treatment

Observability pipelines are not neutral. They may sample, redact, transform, enrich, buffer, reorder, route, or drop telemetry before it reaches the investigator. For CIFM, collector configurations, processor rules, sampling policies, redaction logic, exporter paths, backend retention, and access logs are **evidence environment artifacts** and must be preserved or documented.

Where processors perform redaction or filtering, investigators should document whether raw telemetry was retained, whether redaction was deterministic, whether linkage values were preserved, and whether the transformed record can still be tied to original artifacts. Hashes should reference the earliest recoverable representation of the telemetry. If only transformed telemetry is available, the transformation must be explicitly recorded as a confidence constraint.

9.3.2.4 Context Propagation and Execution Boundaries

AI-agent workflows frequently cross execution boundaries—shells, subprocesses, tools, CI/CD, containers, serverless platforms, APIs, SaaS systems, and business applications. If correlation context does not survive these boundaries, the causal chain fragments. This fragmentation reduces origin-chain confidence and must be recorded as a visibility gap.

A reported tool invocation is not proof of downstream effect. That effect must be corroborated against the system of record.

9.3.2.5 Timestamp and Sequence Integrity

Telemetry timestamps are candidate event times, not guaranteed truth. Investigators should cross-check endpoint time, collector receipt time, backend ingestion time, provider timestamps, and other independent sources where available.

Machine-speed activity can outpace collection fidelity. Buffering, retries, batching, and latency may reorder events. Where available, monotonic sequence identifiers should be preserved and mapped into UEM. Where none exist, ordering must remain bounded by timestamp confidence and documented pipeline behavior.

9.3.3 Shadow Systems, Shadow AI, and Reconstruction Debt

Shadow IT, Shadow AI, and shadow processing are not merely governance failures. They are evidence-chain failures waiting to happen.

When systems, integrations, credentials, and automated processes exist within an organization's operational environment outside the perimeter of governance, visibility, and ownership, they do not cease to be investigative surfaces. They become investigative surfaces that nobody prepared to collect from. An investigator reconstructing a converged infrastructure incident cannot limit their evidence model to officially provisioned systems. Adversaries exploit what exists, not what the organization intended to provision. A SaaS tool acquired on a departmental credit card, an AI integration connected without security review, a scheduled script running on a service account whose owner departed eighteen months ago — each represents a potential access path, data flow, decision point, or action record that may be directly relevant to reconstruction, and each was excluded from the organization's telemetry architecture by the same act of omission that created it.

This subsection defines how CIFM addresses shadow systems as investigative surfaces, and how their presence affects reconstruction confidence.

9.3.3.1 Shadow Systems as Unknown Evidence Sources

Shadow IT — unsanctioned applications, services, and infrastructure procured or deployed outside IT governance — creates investigative surfaces that may not be known to responders at the time of evidence collection. If a SaaS tool, third-party integration, personal cloud storage instance, or unreviewed API connection was never inventoried, investigators may not know to request records from it, may not have contractual or legal authority to access it, and may not be able to establish that data flows through it were relevant to the incident.

The investigative consequence is precise: absence of evidence from an unknown source cannot be distinguished from absence of evidence from a known source with no relevant activity. Both produce silence in the telemetry record. Only one of them means nothing happened there.

Unexplained gaps in activity timelines, unresolved API calls to unrecognized endpoints, and data flows to unaccounted destinations must be treated as potential indicators of shadow system presence and documented as candidate Dark domains in the Visibility & Trust Boundary Matrix, pending investigation. They must not be treated as clean gaps in the absence of positive evidence that the domain does not exist.

9.3.3.2 Shadow AI and Ungoverned AI Decision Paths

Shadow AI is a subset of shadow IT specific to AI tooling: large language models, AI coding assistants, automated workflow tools, retrieval-augmented generation pipelines, and AI-agent frameworks integrated into operational processes without organizational awareness or security review.

Shadow AI deployments are forensically significant because each integration typically creates API connections, OAuth grants, delegated identity credentials, prompt histories, tool invocation logs, model output records, and retrieval context that may become directly relevant to reconstruction — but only if the organization knows the deployment exists and has preserved its artifacts. These artifacts are the same categories addressed in Section 9.3.2 for governed AI-agent telemetry. The operative difference is that shadow AI deployments are not subject to the audit, logging, and retention requirements that governed deployments carry. Their artifacts may exist in vendor-controlled infrastructure the organization has no forensic access to, or may not exist at all.

The investigative surface of a shadow AI deployment includes: the identity credentials created for or by the integration; the data flows established between the AI tool and internal systems; any tool calls, downstream API calls, or automated actions taken on behalf of the AI agent; and the prompt and output history of the deployment where retained.

Where these artifacts are not preserved — because the deployment was not known and therefore not included in forensic readiness planning — their absence must be classified as a visibility gap, not a clean state. The absence of expected AI-agent telemetry from a pathway of interest is not evidence that no AI-agent activity occurred. It is a signal that the investigator should determine whether ungoverned AI deployments exist in the environment before treating the gap as exculpatory.

For AI-driven operational incident investigations, see Appendix B. The shadow AI investigative surface is a direct extension of the AI-driven incident framework: ungoverned AI deployments represent the class of AI-agent activity most likely to lack the structured telemetry that Section 9.3.2 and Appendix B assume.

9.3.3.3 Shadow Processing and Orphaned Automation

Shadow processing encompasses automated jobs, scheduled scripts, API call chains, cloud functions, CI/CD pipeline components, and background processes that run independently of human oversight. Shadow processing typically originates as a legitimate automation that loses its governing owner when the responsible individual changes roles or leaves the organization. The process continues to run. Its permissions persist. Its actions continue to generate operational effects and, potentially, telemetry records attributed to credentials that no longer have an accountable owner.

From a reconstruction standpoint, shadow processing creates autonomous activity streams with no current accountable human owner, operating on potentially stale permissions, against systems the original creator may not have anticipated the process would reach. These activity streams may appear in telemetry as expected machine behavior. They may not trigger anomaly detection calibrated to human behavioral patterns. An adversary who discovers an active shadow processing credential inherits its operational context and its normalcy.

Investigators encountering scheduled jobs, recurring API calls, or automated scripts associated with orphaned or unverifiable service accounts should treat these as candidate autonomous activity sources requiring ownership verification, purpose assessment, and blast radius evaluation before their outputs are classified as expected background noise rather than candidate evidence.

9.3.3.4 Non-Human Identity, Ownership Gaps, and Blast Radius Drift

Non-human identity in the shadow environment context extends the NHI treatment in Section 9.2 to address two conditions specific to ungoverned access accumulation.

The ownership gap. NHI credentials created through ungoverned processes — a personal API key established for a one-time integration, an OAuth grant created by a tool deployment outside security review — may have no documented owner and no path to revocation through standard access review processes. When such credentials surface during investigation, the honest organizational answer to “whose is this” is frequently: nobody’s, at least not anymore. This is not an edge case. It is the default state of ungoverned NHI in organizations that have grown faster than their governance processes. Orphaned ownership is both a reconstruction constraint and an elevated-risk indicator: a credential with no current accountable owner is a credential whose use cannot be positively authorized or denied from organizational records.

Blast radius drift. A permission grant scoped appropriately to a limited dataset or integration at the time of creation may, over time, reach data, systems, and business processes that did not exist when the grant was established — because the underlying SaaS service expanded its integration scope, because the organizational data architecture changed, or because connected systems grew around the original integration. The permission did not change. The operational reach of that permission did. An adversary

inheriting a compromised NHI credential inherits its current blast radius, not its original intended scope. This drift is silent: no access review was triggered, no re-authorization was requested, and no telemetry records the expansion.

Investigators assessing NHI in a shadow environment context should apply blast radius evaluation to each discovered credential: what can this credential currently reach, and has that scope received authorization relative to its current reach rather than its original purpose?

9.3.3.5 Investigative Archaeology of Ungoverned Access

Standard asset audit methodology is insufficient for shadow system investigation. Audit thinking — verifying known assets against known categories — presupposes that the investigator knows what to look for. The defining characteristic of shadow systems is that nobody knows they are there. A more productive investigative posture borrows from archaeology: arriving at an environment with methods for uncovering what accumulated without anyone intending to leave a record, rather than a checklist for verifying what the organization intended to provision.

For each discovered ungoverned asset, identity, integration, or automated process, CIFM investigators should apply five orienting questions. These questions do not replace the CIFM investigation workflow; they extend Phase 1 infrastructure context assessment and Phase 2 identity analysis into the shadow environment that official architecture documentation does not capture.

Does it exist? (Presence.) What does the current environment contain that official inventory did not anticipate? Unexplained API endpoints, unrecognized service accounts, OAuth grants with unfamiliar scopes, AI integrations absent from the asset register, and automated processes with no documented owner are all potential shadow artifacts requiring investigative accounting.

Who created it, and are they still here? (Ownership.) Can the credential, integration, or process be traced to a current organizational owner with authority to verify its purpose and authorize its continued operation? Orphaned ownership is the primary structural indicator of shadow system risk and a primary constraint on investigative confidence.

When was it last used, and by what? (Activity.) Is this asset dormant, in regular use, or recently activated? Recent activation of a long-dormant credential or integration is a reconstruction-relevant event requiring sequencing within the incident timeline. Sustained activity on an orphaned credential during or adjacent to the incident window is a high-priority investigative focus.

What can it currently reach? (Blast radius.) What systems, data, and downstream integrations are accessible from this credential or process today, accounting for scope changes since its creation? This is an investigative question, not an audit question — the answer defines the potential impact surface of any adversary activity through this pathway, and that surface may differ substantially from what organizational records suggest.

What problem was it solving, and is that problem still real? (Purpose.) Is there an ongoing organizational purpose for this asset, or is it residue of a requirement that no longer exists? Purpose-absent assets with active permissions represent residual attack surface with no corresponding organizational benefit and no active human accountability.

The archaeology model and five investigative questions are adapted from: Niemi, C. (2026). Only the Shadow Knows. The framing has been translated into CIFM investigative language; the underlying conceptual structure is Niemi's.

9.4 Phase 4 – Behavioral Reconstruction

Determine initial access, touched systems, and lateral movement.

9.4.1 Guiding Questions

- **Initial access:** What was the likely initial access vector (phishing, credential stuffing, supply chain, insider)?
- **Sequence of touchpoints:** Which systems were touched, and in what order? (List by timestamp and domain.)
- **Movement characterization:** Was movement lateral (within domain), vertical (privilege escalation), or cross-domain (cloud → edge → OT)?
- **Evidence mapping:** Which UEM entries support each step? Which artifacts contradict the hypothesis?
- **Alternative explanations:** What benign or non-adversarial processes could explain the observed activity?
- **Confidence assessment:** For each hypothesis, assign a confidence assessment and list missing evidence that would increase confidence.

9.4.2 Reconstruction Output

- A prioritized set of hypotheses with supporting UEM entries, confidence assessments, and a list of required follow-up actions (e.g., request provider logs, interview operator, preserve historian snapshot). Confidence assessment (High / Medium / Low) based on evidence completeness, cross-domain corroboration, and visibility gaps.

9.5 Phase 5 – Hybrid Intelligence Analysis

AI accelerates correlation but must remain subordinate to human validation. Hybrid intelligence is treated as a capability multiplier within defined constraints, not a replacement for human judgment.

9.5.1 Human-in-the-Loop (HITL) Validation Tiers

- **Tier 1 — Automated:** Low-level telemetry clustering, anomaly scoring, and initial correlation. Outputs are labeled *suggestions* and must be traceable to UEM entries.
- **Tier 2 — Hybrid:** AI generates hypotheses and candidate timelines; human investigators verify primary sources and annotate model outputs. All verification steps are logged.
- **Tier 3 — Human-Only:** Final narrative reconstruction, evidentiary evaluation, and attribution decisions are made by humans. AI outputs are explicitly documented but not used as sole evidence.

Documentation Requirements: For each AI-assisted result, record model version, prompt/parameters, input UEM subset, and human verification steps.

Caveat: In practice, boundaries between HITL tiers may blur under time pressure; this ambiguity is a known operational condition and should be documented where relevant.

9.6 Phase 6 – Narrative Reconstruction

Translate validated hypotheses into a coherent timeline and operational narrative suitable for legal, operational, and executive audiences. Include visibility constraints and confidence annotations.

9.6.1 Confidence Assessment (Bounded Structure)

CIFM uses a bounded confidence structure—High, Medium, Low—to characterize the strength of reconstructed events and hypotheses. Confidence levels are based on three factors:

- Evidence completeness: availability of primary artifacts supporting the event
- Cross-domain corroboration: independent signals from multiple telemetry sources
- Visibility gaps: documented blind spots that reduce certainty

This structure provides consistency across investigations while preserving the flexibility required for heterogeneous, provider-constrained environments.

9.7 Phase 7 – Attribution & Evidentiary Evaluation

Apply complementary attribution frameworks (e.g., FACT) to evaluate actor intent, capability, and evidentiary weight. Confidence levels from the reconstruction phase (High / Medium / Low) must be preserved and carried forward into attribution analysis.

CIFM produces a **structured hand-off package** consisting of:

- a normalized Unified Evidence Manifest (UEM)
- a cross-domain timeline of validated events
- documented visibility gaps
- and qualitative confidence assessments tied to evidence completeness and corroboration

Attribution frameworks operate on this package to interpret motive, capability, and likely actor alignment.

CIFM does not perform attribution; it establishes the evidentiary foundation required for attribution to be meaningful and defensible.

To preserve analytical integrity:

- provenance of all artifacts must be maintained
- normalization decisions and assumptions must remain visible
- confidence assessments and visibility gaps must be carried forward into attribution analysis

The output of this phase is not a definitive actor claim, but a **contextualized interpretation grounded in validated evidence**, suitable for integration into threat intelligence, operational response, and legal proceedings. Without this structured evidentiary foundation, attribution assessments risk being influenced by incomplete or uncorrelated data. Attribution frameworks inherit both the strengths and limitations of the underlying evidence; incomplete or biased reconstruction will propagate into

attribution outcomes. For organizations beginning with limited visibility, Section 9.8 outlines a Minimum Viable CIFM Implementation (MVI) that enables teams to apply the reconstruction workflow in a constrained domain and expand coverage as telemetry improves.

9.8 – Minimum Viable CIFM Implementation (MVI)

CIFM is designed to operate across converged infrastructure ecosystems, but organizations do not need full cross-domain visibility to begin applying the model. A minimum viable implementation provides a low-friction entry point that allows teams to adopt CIFM incrementally while building investigative capability over time. This path is **illustrative rather than prescriptive**; teams may begin in any domain where visibility is strongest.

A Minimum Viable CIFM implementation consists of four foundational steps:

1. Establish Identity and Control-Plane Visibility (Single Domain)

Select one domain—most commonly cloud—and ensure that identity and control-plane telemetry is retained and accessible. Examples include:

- Cloud identity provider logs
- API activity (e.g., AWS CloudTrail, Azure Activity Logs, GCP Admin Activity Audit Logs)
- Temporary credential issuance and service account activity

This provides the investigative anchor for initial reconstruction.

2. Collect Basic Network Telemetry

Enable lightweight network visibility within the same domain to support correlation. Examples include:

- VPC Flow Logs or equivalent
- Gateway or load balancer access logs
- Basic connection metadata (source, destination, port, protocol, accept/deny)

This establishes the minimum cross-signal correlation surface.

3. Construct a Partial Unified Evidence Manifest (UEM)

Normalize a small subset of events into UEM format using only the essential fields:

- Event Time (UTC)
- Infrastructure Domain
- Actor Identity or Identity Proxy
- Action Verb
- Object Target
- Outcome

Even a partial UEM enables reproducible correlation and hypothesis formation.

4. Perform a Single-Domain Reconstruction Exercise

Select one identity event or control-plane action and trace its associated network and execution activity. Document:

- Supporting UEM entries
- Visibility gaps
- Confidence level (High / Medium / Low)
- Missing evidence that would increase confidence

This exercise establishes the iterative workflow loop and provides a defensible starting point for expanding CIFM coverage.

Note on Environment Variability

No two environments are identical. CIFM's domain-agnostic design is intentional—implementation will always require adaptation to the specific telemetry, constraints, and architecture of the environment under investigation.

Outcome

An MVI deployment does not produce full cross-domain reconstruction, but it establishes:

- Identity-first investigative grounding
- A normalized evidence structure (UEM)
- The iterative reconstruction loop
- A repeatable workflow that can expand as visibility improves

This lowers the activation barrier and enables organizations to begin applying CIFM immediately, even with limited telemetry.

10. Iterative Workflow Loop (Diagram)

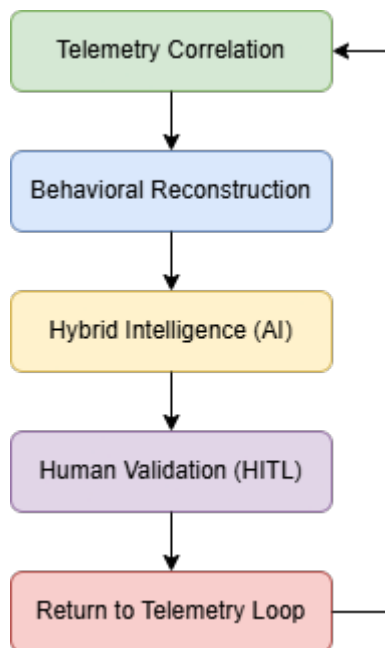


Figure 3. Iterative Workflow Loop diagram.

Textual description

CIFM is intentionally iterative: telemetry correlation surfaces candidate anomalies; behavioral reconstruction forms hypotheses; hybrid intelligence tests and expands hypotheses; human validation confirms or rejects them; new findings return investigators to raw telemetry for deeper collection or re-normalization. This loop continues until a defensible narrative is produced. Assessments of confidence in reconstructed events must be explicitly documented and tied to evidence completeness, corroboration across domains, and identified visibility gaps. CIFM uses a bounded qualitative structure rather than a fixed numerical scoring model.

11. Hypothetical CIFM Case Study

Step-by-step CIFM application

1. **Phase 1 (Visibility):** The team builds a Visibility & Trust Boundary Matrix and discovers full cloud audit logs, partial telecom flow records, limited OT historian snapshots, and dark IoT device logs.
2. **Phase 2 (Identity):** Identity analysis shows a service account issued a temporary token at 02:12 UTC, followed by API calls to create ephemeral compute.
3. **Phase 3 (UEM):** UEM normalization produces a single timeline linking the identity events to network flows and a gateway proxy session. Evidence hashes are recorded.

4. **Phase 4 (Reconstruction):** Investigators hypothesize initial access via credential compromise, lateral movement through cloud automation, and attempted OT gateway access. They list missing evidence (deep packet captures from the telecom provider) and request preservation.
5. **Phase 5 (HITL):** AI clusters similar API patterns and surfaces anomalous automation scripts; human analysts verify the scripts and annotate the model outputs.
6. **Phase 6 (Narrative):** A validated timeline is produced showing identity compromise, cloud provisioning, and attempted OT access; confidence assessments and visibility gaps are documented.
7. **Phase 7 (Attribution):** The team hands the validated timeline and UEM to an attribution team using FACT for further analysis.

Contrast with host-centric approach: A host-centric investigation would likely miss the ephemeral cloud provisioning and control-plane misuse, producing an incomplete or misleading narrative.

12. Investigative Anti-Patterns

- **Treating AI output as authoritative evidence.** AI outputs are suggestions and must be validated against primary UEM entries.
- **Over-reliance on endpoint artifacts.** In converged environments, endpoints may be sparse; control-plane telemetry is often primary.
- **Investigating domains in isolation.** Cross-domain correlation is essential to reveal lateral movement.
- **Failing to document visibility gaps.** Unrecorded blind spots undermine evidentiary claims.
- **Assuming linear progression.** Investigations must be iterative; new telemetry can invalidate prior hypotheses.
- **Assuming identity telemetry is complete:** In supply chain, firmware, or hardware-level compromises, adversary activity may not surface in identity systems.
- **Premature narrative closure:** Declaring an investigation complete before all visibility gaps are documented and alternative hypotheses evaluated.
- **Treating ephemeral workload termination as total evidence loss:** When a container, serverless function, transient VM, or CI runner terminates before imaging, investigators should pivot to preserved control-plane, orchestration, identity, runtime, and network telemetry rather than treating the event as unreconstructable. See Section 14.
- **Treating observability telemetry as a complete narrative.** Traces, spans, log records, and metrics report activity from a particular vantage point. They do not prove completeness, causality, intent, or downstream effect without corroboration.
- **Ignoring collector and processor mutation.** Sampling, filtering, redaction, enrichment, transformation, buffering, retries, and exporter routing can alter what investigators receive. The pipeline configuration is part of the evidence environment.
- **Assuming context propagation survived execution boundaries.** Agent telemetry may fragment when execution crosses shell, subprocess, plugin, connector, CI/CD, container,

serverless, cloud API, SaaS, or business-system boundaries. Broken context propagation must be documented as a visibility gap.

- **Treating tool success as operational effect.** A reported tool result may not prove that the target system committed the action. Downstream systems of record must be checked before narrative claims are made.
- **Confusing prompt or session linkage with intent.** Prompt, session, trace, or interaction identifiers may link events, but they do not by themselves establish human intent, model reasoning, or authorized purpose.
- **Treating absence of AI-agent telemetry as absence of action.** Telemetry may be disabled, sampled, redacted, dropped, expired, or broken at execution boundaries. Absence must be classified as a visibility condition, not an exculpatory fact.
- **Assuming all AI deployments in the environment are governed or visible.** AI tools, agent frameworks, and automated workflow integrations acquired outside formal procurement or security review may operate within the investigative surface without appearing in asset records, telemetry configurations, or forensic readiness plans. Unexplained API activity, unrecognized OAuth grants, and NHI credentials with no documented owner are potential indicators of ungoverned AI deployments. The absence of AI-agent telemetry from a pathway of interest is not evidence that no AI-agent activity occurred; it is a signal requiring shadow environment assessment before the gap is treated as exculpatory. See Section 9.3.3.

13. Forensic Readiness in Converged Environments

While CIFM is presented as an investigative framework, its effectiveness depends heavily on capabilities that must be established prior to an incident. In converged infrastructure environments, investigators cannot retroactively create telemetry, identity visibility, or architectural context. These elements must be designed, enabled, and maintained as part of normal operations.

As a result, CIFM inherently depends on forensic readiness — the organizational practice of designing, enabling, and maintaining investigative capabilities before an incident occurs.

Organizations should adopt forensic-by-design practices:

- **Retention baselines:** Define minimum retention windows for cloud audit logs, identity provider events, network flows, and OT historian snapshots.
- **Standardized telemetry schemas:** Adopt or map to a canonical schema (UEM) to enable cross-domain correlation.
- **Identity provider logging:** Ensure full session and token issuance logs are retained and accessible for investigations.
- **OT/ICS safeguards:** Preserve historian snapshots, PLC event logs, and gateway logs with documented chain-of-custody procedures.

- **AI metadata retention:** Retain model versioning, inference logs, and weights metadata where local ML models are used in operational systems. For AI-driven operational incidents, organizations should also preserve prompts/inputs, model outputs, retrieval context, tool-call logs, delegated identity records, approval paths, and downstream system-of-record changes where available. See Appendix B.
- **Legal and contractual readiness:** Ensure provider contracts permit forensic preservation and that legal processes for cross-provider evidence requests are documented.
- **IACS evidence collection infrastructure:** In environments incorporating Industrial Automation and Control Systems, organizations should consider purpose-built forensics and compliance auditing infrastructure to ensure that IACS telemetry is preserved at forensic quality before incidents occur. Henriques et al. (2023) describe an FCA framework architecture that addresses evidence collection and compliance auditing for distributed IACS environments at scale — representing one concrete approach to fulfilling the forensic readiness dependency that CIFM requires in OT-adjacent deployments.
- **Ephemeral workload telemetry:** Environments operating ephemeral compute (containers, serverless functions, transient VMs) must pre-configure centralized log aggregation, orchestration audit logging, and image provenance tracking before incidents occur. Evidence from ephemeral workloads cannot be acquired post-termination; it must be captured in motion. See Section 14.
- **AI-agent observability readiness:** Environments using AI agents, model-connected tools, workflow automation, or AI-assisted systems should preconfigure retention and export of AI-agent telemetry, including traces, logs, metrics, interaction identifiers, tool invocation records, approval and override records, delegated identity context, and downstream system-of-record changes where available. See Appendix B.
- **Telemetry pipeline preservation:** Organizations should retain collector configuration, processor rules, sampling policies, redaction policies, exporter configuration, backend retention settings, access logs, and configuration-change history for observability pipelines used in investigations. The pipeline configuration is part of the evidence environment.
- **Context propagation readiness:** Organizations should test whether correlation identifiers, session context, identity context, and trace context survive execution boundaries such as subprocesses, shell tools, CI/CD runners, containers, serverless functions, SaaS connectors, and API gateways. Known breaks should be documented in the Visibility & Trust Boundary Matrix.
- **Timestamp and sequence readiness:** Systems should synchronize time sources and preserve endpoint event time, collector receipt time, backend ingestion time, provider timestamps, and monotonic sequence identifiers where available. Timestamp provenance should be recorded with UEM entries.
- **Tamper-evident configuration management:** Telemetry collection should be externally managed, least-privilege controlled, tamper-evident, recoverable, and auditable. Managed endpoint configuration, infrastructure-as-code, signed configuration baselines, immutable storage, and access-controlled pipeline deployment are examples of possible implementation patterns.

- **Shadow system inventory and NHI accountability.** Before an incident occurs, organizations must be able to answer: what non-human identities, OAuth grants, API connections, SaaS integrations, AI tool deployments, and automated processes exist in this environment? Shadow systems, ungoverned AI integrations, and orphaned automations that are not inventoried in advance cannot be included in telemetry collection planning, forensic preservation scope, or legal authority frameworks at the time of investigation. At minimum, organizations should maintain:
 - A current NHI inventory with ownership assignments and documented purpose, subject to periodic review rather than one-time provisioning.
 - An OAuth and API grant registry with documented scope, originating purpose, authorization date, and review cadence — with specific attention to scope drift since authorization.
 - A lightweight intake process for surfacing AI tool integrations before they accumulate as unexamined API connections, data flows, and ungoverned NHI. The standard is not governance maturity; it is investigative visibility. An organization that cannot inventory its AI integrations cannot scope its forensic collection.
 - Offboarding procedures that explicitly surface and remediate NHI and automated access created by or associated with departing individuals — not only the individual’s human credentials.

Organizations that cannot answer the question “what AI tools and automated processes exist in this environment that were not provisioned through formal governance review” have a shadow environment that is invisible to their forensic readiness planning. See Section 9.3.3.

14. Ephemeral Workload Handling

Ephemeral workloads — short-lived containers, serverless functions (e.g., AWS Lambda, Google Cloud Run, Azure Functions, CI runners), transient compute instances, and batch job tasks — present a distinct investigative challenge in converged infrastructure environments. These workloads frequently terminate before traditional acquisition is possible, eliminating host-level artifacts entirely. CIFM does not assume that ephemeral workloads can be imaged or recovered after the fact.

Instead, CIFM treats ephemeral compute as transient evidentiary events whose activity must be reconstructed from surrounding telemetry that persists beyond the workload's lifetime. The investigative unit is not the container or function instance itself — it is the *ephemeral workload event*: the set of control-plane, orchestration, identity, and runtime signals that together describe what the workload did, under which identity, and with what effect.

14.1 Investigative Posture

CIFM reconstructs ephemeral workload behavior through preserved, upstream evidence sources, including:

- *Control-plane telemetry*: orchestration events, audit logs, provisioning actions (e.g., Kubernetes API audit logs, ECS/Fargate task lifecycle events, CloudTrail CreateFunction/InvokeFunction records).
- *Identity and access activity*: service accounts, IAM roles, token issuance, workload identity bindings, and privilege escalation chains associated with the workload's execution context.
- *Image provenance*: container registry pull records, image digests, build pipeline metadata, and deployment manifests that establish what code ran and from where it was sourced.
- *Network and service-mesh telemetry*: flow logs, DNS queries, proxy events, and service mesh records capturing what the workload communicated with during its lifetime.
- *Centralized runtime logs*: stdout/stderr aggregation, application logs, and structured event streams exported from the workload before or during termination.
- *Node-level or runtime sensors (where deployed)*: eBPF-based runtime sensors, container runtime events, and syscall traces where pre-incident instrumentation exists. This capability is generally applicable to node-backed container environments and should not be assumed available for provider-managed serverless execution.

These sources form the evidentiary basis for reconstructing the workload's lifecycle, behavior, and impact.

Note on serverless functions: Serverless execution environments (Lambda, Cloud Run, Azure Functions, and equivalents) present a materially different telemetry profile than container workloads. No node-level access or runtime sensor data is typically available; evidence is heavily dependent on provider-controlled logs (invocation records, execution logs, cold-start metadata) and service-mesh or API gateway telemetry. Investigators should not assume that telemetry sources applicable to containerized workloads are available in serverless contexts. Provider-specific log retention limits and aggregation latency must be assessed in the Visibility & Trust Boundary Matrix before reconstruction begins.

14.2 Reconstruction, Not Recovery

CIFM explicitly distinguishes between two investigative modes:

- **Recovery** — acquiring artifacts directly from a persistent host (disk image, memory capture, filesystem analysis).
- **Reconstruction** — deriving workload behavior from correlated telemetry sources that persist beyond the workload's termination.

Ephemeral workloads fall into the reconstruction category. When no direct artifacts exist, CIFM reconstructs:

- *Creation and scheduling events* — who or what initiated the workload, and through which mechanism.
- *Image lineage and deployment source* — which image digest was executed, and from which registry and pipeline it originated.
- *Identity context and privilege boundaries* — which service account or IAM role the workload assumed, and what permissions were available.
- *Network interactions and resource access* — what the workload communicated with, including internal services, external endpoints, and data stores.
- *Termination conditions and timing* — how and when the workload terminated, including exit codes and any anomalous termination signals.

The investigative unit is the **ephemeral workload event**, not the container or instance itself. This distinction is essential: investigators must not treat the absence of a host image as a total evidence loss. The surrounding telemetry is the evidence. Behavioral reconstruction remains possible even when the orchestrator lacks a record of the initiating event; reconstruction proceeds from preserved runtime, node-level, identity, and network telemetry rather than from declared orchestration state.

14.3 Runtime-Spawned Workloads and Undeclared Execution Paths

Ephemeral workloads may be created dynamically by jobs, parent containers, CI/CD runners, entrypoint scripts, automation frameworks, privileged workloads, or compromised workloads, and may not appear in the original deployment manifest, compose file, or declared orchestration configuration. In these cases, the orchestrator's view may represent declared or partial lifecycle state rather than a complete record of actual execution.

CIFM distinguishes between:

- *Declared State* — what the environment was intended to run
- *Observed State* — what preserved telemetry proves actually ran
- *Initiating Mechanism* — the process, identity, workload, or automation path that created the workload
- *Origin Chain Confidence* — the degree to which the initiating mechanism can be corroborated

When the orchestrator lacks a durable record of the initiating action, investigators should pivot to **runtime, node-level, registry, CI/CD, identity, and network telemetry** to identify the most likely origin chain. If the initiating mechanism cannot be corroborated, CIFM permits reconstruction of the child workload's observed behavior but requires the origin chain to be documented as a visibility gap with corresponding confidence impact.

This condition is common in environments where workloads are spawned dynamically at runtime and should be treated as a standard ephemeral workload scenario rather than an exception.

14.4 Visibility Gaps and Confidence Impact

When telemetry necessary for reconstruction is missing — because it was never retained, because provider-controlled logs were not enabled, or because retention windows expired before the investigation began — CIFM requires investigators to:

- Document the missing artifact type in the UEM, using the Ephemeral Workload Extension fields (see Section 9.3.1).
- Identify compensating evidence, if any, that partially substitutes for the missing source.
- Quantify the visibility gap using the Visibility & Trust Boundary Matrix, assigning the affected domain a *Partially Visible* or *Dark* classification as appropriate.
- Carry the resulting confidence impact forward into the final narrative and conclusions.

CIFM prohibits inferring workload behavior beyond what preserved telemetry can support. Where the evidence is absent, the gap must be named, classified, and carried as an explicit uncertainty in the investigative narrative. Furthermore, reconstruction claims must not exceed the evidentiary scope of preserved telemetry. When the initiating mechanism for a runtime-spawned workload cannot be corroborated, the origin chain **must** be marked as a visibility gap, and confidence in any claim about workload provenance must be reduced accordingly.

14.5 Forensic-by-Design Readiness for Ephemeral Environments

Because ephemeral workloads cannot be acquired post-termination, CIFM's forensic-by-design principle applies with particular force in ephemeral compute environments. Organizations operating containerized or serverless workloads should establish the following before incidents occur:

- *Centralized log aggregation*: Ensure stdout/stderr and application logs are exported to a persistent log store, such as CloudWatch Logs, Google Cloud Logging, Azure Monitor Logs, Splunk, or equivalent, before workload termination. Local-only logs are lost when the container exits.
- *Orchestration audit logging*: Enable full audit logging for the container orchestration control plane (Kubernetes API server audit logs, ECS task event streams, Fargate execution records).
- *Image provenance tracking*: Maintain pull records and image digests in a registry that retains this data beyond the workload's lifetime.
- *Network flow visibility*: Ensure VPC flow logs, service mesh telemetry, or equivalent network records are enabled and retained for workloads of interest.
- *Runtime sensors for high-risk workloads (optional)*: For workloads with elevated privilege or access to sensitive resources, consider deploying eBPF-based runtime sensors or equivalent instrumentation that captures syscall and network activity in a persistent external store.
- *Retention window alignment*: Ensure that log retention windows for ephemeral workload telemetry meet or exceed the organization's incident response and investigation timeframes.

Short retention windows are the most common source of unrecoverable evidence loss in ephemeral environments.

Ephemeral workload forensics is only reliable when telemetry exists before the workload terminates. The investigation cannot create evidence that was never captured.

15. Relationship to FACT

CIFM focuses on evidence discovery and reconstruction across converged infrastructure environments. It produces normalized evidence (UEM), validated timelines, and documented visibility constraints.

CIFM is strongest as a reconstruction framework. It builds the evidence package and establishes a defensible, human-validated timeline across identity, control-plane, telemetry, and OT domains.

Attribution frameworks such as FACT then take on the separate question of whether that reconstructed activity can be linked to a real-world person under legal and evidentiary constraints — with alternative explanations considered, and with the option to stop short of attribution when the evidence does not support it.

This boundary is intentional. CIFM does not perform attribution. It builds the evidentiary foundation that attribution frameworks depend on. The two are complementary rather than competitive — CIFM produces what FACT requires to do its work with integrity.

CIFM's outputs are designed to be directly consumable by attribution workflows while preserving human-validated provenance throughout.

16. Limitations and Future Work

CIFM is designed to operate in environments characterized by incomplete, heterogeneous, and unevenly distributed telemetry. Real-world investigations rarely provide full visibility across all domains; instead, investigators must reconstruct activity using partial evidence, provider-constrained logs, and evolving data availability. The following limitations do not represent failure conditions of the model, but rather the operational realities within which CIFM is intended to function. Confidence assessments reflect the bounded structure defined in Section 9, and are directly influenced by documented visibility gaps.

16.1 Telemetry Visibility Constraints

CIFM depends on the availability and quality of telemetry. Provider-controlled logs, contractual limitations, and ephemeral device telemetry can create blind spots that reduce reconstruction confidence. Investigators must document these gaps and quantify their impact on conclusions. CIFM addresses these conditions by explicitly modeling visibility gaps through the Visibility and Trust Boundary Matrix and incorporating confidence-based reasoning into reconstruction.

In some environments, identity telemetry may be anonymized, tokenized, or otherwise abstracted due to privacy, regulatory, or legal constraints. This can limit direct attribution of actions to specific users or service accounts and requires investigators to correlate identity proxies (e.g., pseudonymous tokens,

hashed identifiers, or domain-specific surrogate IDs) across systems. In these cases, investigators treat the anonymized token, hash, or surrogate identifier as an **identity proxy**—a stand-in that enables correlation of activity across systems even when the underlying user or service account cannot be directly revealed.

16.2 Provider and SaaS Opacity

Cloud and SaaS providers may limit access to low-level artifacts or retain only aggregated logs. This can constrain the granularity of reconstruction and require legal or contractual remedies to obtain necessary evidence.

16.3 Retention and Preservation Gaps

Short retention windows for critical logs (e.g., identity provider sessions, network flows) can prevent investigators from reconstructing historical activity. Forensic readiness planning must address retention baselines.

16.4 Domain Expertise Requirements

Effective CIFM investigations require cross-domain expertise (cloud, telecom, OT, IoT). Organizations must invest in multidisciplinary teams or external partnerships to interpret domain-specific telemetry correctly.

16.5 Hybrid Intelligence Risks

AI assistance accelerates analysis but introduces risks: model drift, adversarial manipulation, and opaque reasoning. CIFM mitigates these risks through HITL tiers, model versioning, and mandatory human verification, but residual risk remains.

AI-driven operational incidents introduce additional risks when AI systems are both part of the evidence chain and part of the investigative workflow. Appendix B extends CIFM's HITL constraints to AI-linked evidence sources, tool invocations, retrieval pipelines, and AI-assisted reconstruction.

16.6 Legal and Privacy Constraints

Investigations across domains and jurisdictions raise legal and privacy considerations. CIFM does not replace legal counsel; it requires integration with legal and compliance processes to ensure evidence collection is lawful and defensible.

Future Work

- Standardize UEM mappings for common providers and OT vendors.
- Develop open reference implementations for UEM ingestion and hashing.
- Evaluate CIFM in tabletop and red/blue exercises across cloud/OT/telecom scenarios.
- Research reproducibility and audit trails for AI-assisted reconstruction.
- Develop standardized UEM mappings and readiness checklists for ephemeral workload environments across major cloud providers.
- Develop practitioner implementation worksheets and limited-scope training labs for the Visibility & Trust Boundary Matrix, Minimum Viable CIFM implementation, NHI/token inventory, and shadow environment assessment. These materials should help teams identify visible, partially visible, and dark domains; document evidence ownership and collection

authority; surface shadow system indicators; and practice bounded reconstruction using limited but defensible telemetry.

17. Conclusion

CIFM represents a practical evolution of digital forensics for the era of converged infrastructure. By prioritizing infrastructure context, identity-centric analysis, telemetry normalization (UEM), iterative reconstruction, and human-in-the-loop validation, CIFM provides investigators with a defensible, operational methodology for reconstructing complex, cross-domain incidents. The model is intentionally pragmatic: it measures visibility, normalizes evidence, and constrains AI assistance so that human investigators retain final authority.

Operational patterns documented in campaigns such as Volt Typhoon demonstrate that this investigative gap is active, not theoretical. Given the increasing frequency of campaigns that exploit control-plane mechanisms and identity systems, CIFM provides a structured approach to improving investigative completeness, reducing false narratives, and strengthening the evidentiary basis for operational and legal decisions. Future work will focus on standardization, tooling, and empirical validation through exercises and case studies.

18. Glossary

- **Control-plane:** The set of APIs, identity services, and orchestration mechanisms that manage infrastructure.
- **Telemetry Fabric:** The combined set of logs, flows, sensor data, and control-plane events across domains.
- **UEM (Unified Evidence Manifest):** Canonical schema for normalized evidence records.
- **HITL (Human-in-the-Loop):** Validation model where humans verify AI outputs.
- **Visibility Matrix:** A domain-by-domain assessment of telemetry availability and confidence.
- **Converged Infrastructure:** Interconnected cloud, telecom, edge, IoT, and OT ecosystems.
- **Confidence Assessment:** A qualitative evaluation of the reliability of reconstructed events based on evidence completeness, cross-domain corroboration, and documented investigative gaps.
- **Defensible Narrative:** A reconstructed account of adversary activity supported by validated evidence, documented assumptions, explicit confidence levels, and clearly identified visibility gaps, suitable for operational, executive, or legal decision-making.
- **Identity Proxy:** A pseudonymous identifier that represents a user or service account when direct identity attribution is obscured, tokenized, or legally restricted.
- **Ephemeral Workload:** A short-lived compute resource (container, serverless function, transient VM, batch job task) that may terminate before traditional forensic acquisition is possible.

- **Ephemeral Workload Event:** The investigative unit for ephemeral compute — the set of control-plane, orchestration, identity, and runtime signals that together describe what an ephemeral workload did, under which identity, and with what effect.
- **Reconstruction:** The investigative method of deriving workload or adversary behavior from correlated telemetry sources, as distinguished from recovery (direct artifact acquisition from a persistent host).
- **AI-Driven Operational Incident:** An incident in which an AI system, autonomous agent, retrieval pipeline, model-connected tool, or AI-connected workflow acts as an initiating mechanism, propagation vector, decision-layer amplifier, authority/workflow intermediary, evidence source, or investigative risk surface.
- **Actor-Adjacent Control Surface:** An AI-linked system or workflow component that does not constitute an independent actor but can translate model output, tool invocation, delegated identity, or automation state into operational effect.
- **AI Evidence Chain:** The relationship between input, model or retrieval context, output, tool/action path, identity authority, downstream effect, and corroborating telemetry.
- **AI-Agent Observability:** The collection and correlation of telemetry emitted by AI agents, model-connected tools, workflow orchestrators, or surrounding systems to understand reported operational behavior.
- **Agent Trace:** A trace or span chain that represents reported AI-agent activity. It supports behavioral reconstruction but is not self-authenticating proof.
- **Collector Pipeline:** The telemetry collection and processing path through receivers, processors, exporters, and backends. In CIFM, this pipeline is part of the evidence environment.
- **Context Fragmentation:** Loss or breakage of correlation context across execution boundaries, reducing confidence in causal reconstruction.
- **Downstream System of Record:** The authoritative system whose logs, database state, files, commits, API records, or business events can confirm or contradict a reported tool action.
- **Operational Observability Artifact:** Telemetry that reports system behavior from a particular vantage point. It may support reconstruction but does not establish a validated event without corroboration.
- **Validated Event:** A UEM entry whose provenance, timestamp confidence, collection path, and downstream effect have been sufficiently documented and corroborated for narrative use with stated confidence. Distinguished from a reported or corroborated event, which has not yet met the validation threshold.
- **Non-Human Identity (NHI):** A credential, token, key, certificate, or service account that authenticates as something other than a named human user. NHI encompasses API keys, OAuth tokens, service accounts, CI/CD pipeline credentials, machine-to-machine certificates, and automation credentials. NHI credentials do not appear in employee directories, do not carry organizational ownership assignments by default, and generate behavioral patterns architecturally distinct from human identity activity. See Section 9.2 and Section 9.3.3.

- **Shadow AI:** A subset of shadow IT specific to AI tooling: large language models, AI coding assistants, automated workflow tools, agent frameworks, retrieval-augmented generation pipelines, and AI-connected integrations deployed within an organization's operational environment without formal governance review, security approval, or organizational awareness. Shadow AI deployments may create undocumented API connections, OAuth grants, delegated identity credentials, prompt histories, and tool invocation records that become forensically relevant in incident reconstruction but were excluded from forensic readiness planning by the same omission that created them. See Section 9.3.3.
- **Shadow IT:** Unsanctioned applications, services, and infrastructure procured or deployed outside IT governance processes. Includes SaaS subscriptions acquired without IT review, personal cloud storage used for organizational data, third-party integrations connected without security approval, and AI tool deployments outside formal procurement. Shadow IT creates investigative surfaces that may not appear in official asset inventories, telemetry architectures, or forensic readiness plans. See Section 9.3.3.
- **Shadow Processing:** Automated jobs, scheduled scripts, API call chains, cloud functions, CI/CD pipeline components, and background processes that run independently of human oversight, typically originating as legitimate automations that have lost their accountable owner through personnel changes. Shadow processing creates autonomous activity streams operating on potentially stale permissions with no current human accountability. See Section 9.3.3.

References

- Alshamrani, A., Myneni, S., Chowdhary, A., & Huang, D. (2022). *A survey on extended detection and response (XDR): Architectures, techniques, and open challenges*. IEEE Access, 10, 10357–10376. <https://doi.org/10.1109/ACCESS.2022.3144735>
- Casey, E. (2011). *Digital evidence and computer crime: Forensic science, computers, and the internet* (3rd ed.). Academic Press.
- CISA. (2024). *People's Republic of China state-sponsored cyber actor living off the land to evade detection*. Cybersecurity and Infrastructure Security Agency. Retrieved from <https://www.cisa.gov/news-events/alerts>
- CISA & ICS-CERT. (2016). *Recommended practice: Improving industrial control system cybersecurity with defense-in-depth strategies*. Cybersecurity and Infrastructure Security Agency.
- Gartner. (2024). *Market guide for extended detection and response*. Gartner, Inc. <https://www.gartner.com/en/documents/5859979> (subscription required)
- Henriques, J., Caldeira, F., Cruz, T., & Simões, P. (2023). A forensics and compliance auditing framework for critical infrastructure protection. *International Journal of Critical Infrastructure Protection*, 42, 100613. <https://doi.org/10.1016/j.ijcip.2023.100613>

- Kamar, E. (2016). Directions in hybrid intelligence: Complementing AI systems with human intelligence. *Proceedings of the 25th International Joint Conference on Artificial Intelligence (IJCAI-16)*, 4070–4073. <https://dl.acm.org/doi/10.5555/3061053.3061219>
- Moyle, S. et al. (2024). “XAI Human-Machine collaboration applied to network security,” *Frontiers in Computer Science*. <https://doi.org/10.3389/fcomp.2024.1321238>
- Nance, K., & Ryan, D. J. (2011). Legal aspects of digital forensics: A research agenda. *Proceedings of the 44th Hawaii International Conference on System Sciences*. IEEE.
- NERC. (2024). *Critical infrastructure protection (CIP) standards*. North American Electric Reliability Corporation.
- NIST. (2023). *Special Publication 800-92: Guide to computer security log management*. National Institute of Standards and Technology. (Draft Rev.1, 11 Oct 2023).
- NIST. (2017). *Special Publication 800-63-3: Digital identity guidelines*. National Institute of Standards and Technology.
- NIST. (2020). *Special Publication 800-207: Zero trust architecture*. National Institute of Standards and Technology.
- Oriwoh, E., Jazani, D., Epiphaniou, G., & Sant, P. (2013). Internet of Things forensics: Challenges and approaches. *Proceedings of the 9th International Conference on Collaborative Computing*. IEEE.
- Quick, D., & Choo, K. R. (2013). Impacts of increasing volume of digital forensic data: A survey and future research challenges. *Digital Investigation*, 10(4), 273–294. <https://doi.org/10.1016/j.diin.2013.10.002>
- Ruan, K., Carthy, J., Kechadi, T., & Crosbie, M. (2011). Cloud forensics: An overview. *Advances in Digital Forensics VII*, IFIP AICT, vol. 361. Springer.
- Stoyanova, M., Nikoloudakis, Y., Panagiotakis, S., Pallis, E., & Markakis, E. (2020). A survey on the Internet of Things forensics: Challenges, approaches, and open issues. *IEEE Communications Surveys & Tutorials*, 22(2), 1191–1221.
- Zawoad, S., & Hasan, R. (2015). FAIoT: Towards building a forensics-aware ecosystem for the Internet of Things. *Proceedings of the 2015 IEEE International Congress on Internet of Things*. IEEE.
- Anthropic. (2025). Disrupting the first reported AI-orchestrated cyber espionage campaign. Anthropic. <https://www.anthropic.com/news/disrupting-AI-espionage>
- MITRE ATT&CK. (2026). Anthropic AI-orchestrated Campaign, Campaign C0062. MITRE. <https://attack.mitre.org/campaigns/C0062/>
- OpenTelemetry. (2024). *Documentation, signals, collector, and semantic conventions*. <https://opentelemetry.io/docs/>
<https://opentelemetry.io/docs/concepts/signals/>
<https://opentelemetry.io/docs/collector/>
<https://opentelemetry.io/docs/concepts/semantic-conventions/>

OpenTelemetry. (2024). *Semantic conventions for generative AI systems and agent frameworks* (development status at time of citation).

<https://opentelemetry.io/docs/specs/semconv/gen-ai/>

<https://opentelemetry.io/docs/specs/semconv/gen-ai/gen-ai-agent-spans/>

<https://opentelemetry.io/docs/specs/semconv/gen-ai/gen-ai-spans/>

Niemi, C. (2026). Only the Shadow Knows: On Shadow Systems and the Visibility Gap Organizations Don't Know They Have. May 2026.

Author Note

The CIFM framework is a work in progress and is intended to evolve through peer feedback, research, and practical application.

About the Author

Kerry Hazelton, also known as *Professor Kilroy*, has worked in technology and cybersecurity since 2000, with experience spanning IT systems, data center operations, cloud computing, digital forensics, and incident response.

Over the past decade, he has developed and delivered hands-on training workshops on network analysis and cloud forensics at security conferences across the United States, including BSides Seattle, BSides Las Vegas, BSides Kansas City, BSides Delaware, BSides Charm, and DEF CON 33.

His recent workshops explore investigative techniques for modern infrastructure ecosystems where cloud platforms, IoT systems, edge computing, and operational technology increasingly intersect. These workshops also incorporate collaborative analytical approaches involving human investigators and digital intelligence assistants to explore the emerging role of hybrid intelligence in cybersecurity investigations.

The **Converged Infrastructure Forensics Model (CIFM)** reflects the ideas developed through these teaching experiences and ongoing research into investigative methodologies for complex, distributed computing environments.

Acknowledgments

The author publicly acknowledges and thanks the following individuals for their time and effort in reviewing this framework and providing feedback, which has been incorporated throughout:

- Mr. Joshua Marpet
- Mr. Jeff Man
- Mr. Mick Baccio
- Mr. James Honeycutt

The author also exclusively acknowledges and thanks his father and stepmother for their time, effort, and feedback for reviewing this framework; and to thank his father for his service to his country as a twenty-year veteran of the United States Navy.

The author publicly acknowledges and thanks Mr. Brett Shavers, author of the FACT framework, for his review of this work and his confirmation of their complementary relationship; and Professor Charlie Niemi, MSIA, CISSP, MBA, from the Oklahoma Cyber Innovation Institute at the University of Tulsa for the shadow environment framework and the archaeological investigative model that informed Section 9.3.3 of this document. The five investigative questions in Section 9.3.3.5 are adapted from Niemi (2026) and translated into CIFM investigative language with his knowledge and permission.

Appendix A — CIFM Incident Response Field Guide

Before You Use This Guide: This field guide assumes familiarity with CIFM’s identity-centric approach, iterative workflow, and evidence normalization model. Refer to Sections 9 and 10 for context.

A.1 Purpose

This appendix provides a concise, operational reference for applying the Converged Infrastructure Forensics Model (CIFM) during active investigations. It is intended as a practical guide for investigators operating under time constraints and incomplete telemetry conditions.

CIFM is inherently iterative and designed for real-world environments where visibility may be partial, heterogeneous, or evolving. This field guide is intentionally simplified for operational use and does not replace the full CIFM model described in the main document.

A.2 Confidence Assessment Rubric (High / Medium / Low)

CIFM uses a bounded confidence structure to characterize the strength of reconstructed events and hypotheses. Confidence levels reflect three factors: *evidence completeness*, *cross-domain corroboration*, and *visibility gaps*. The table below provides a concise rubric for applying these levels consistently.

Confidence Level	Criteria
High	• Primary evidence is complete or near-complete • Multiple independent telemetry sources corroborate the event (e.g., identity + network + control-plane) • Visibility gaps are minimal or do not materially affect the conclusion • Alternative explanations have been evaluated and ruled out
Medium	• Primary evidence is partially complete • Some cross-domain corroboration exists, but not all domains are available or aligned • Visibility gaps introduce uncertainty but do not invalidate the hypothesis • Alternative explanations remain plausible and require additional evidence to resolve
Low	• Evidence is sparse, incomplete, or provider-constrained • Little or no cross-domain corroboration is available • Significant visibility gaps materially affect the ability to reconstruct the event • Multiple alternative explanations remain viable

Usage Note

Confidence levels should be applied per reconstructed event or hypothesis, not globally across the entire investigation. Each level must be tied to specific evidence completeness, corroboration strength, and documented visibility gaps.

A.3 CIFM Quick-Start Workflow

A.3.1 Confirm Scope

- Identify the trigger (alert, anomaly, external report)
- Determine the initial domain(s) involved (cloud, telecom, edge, IoT/IIoT, OT/ICS)
- Identify known or suspected identities associated with the activity

A.3.2 Infrastructure Context Assessment

Objective: Establish baseline understanding before artifact analysis

- Identify relevant systems and services
- Map trust boundaries and domain relationships
- Identify identity providers and control-plane dependencies
- Enumerate available telemetry sources

Output: Initial system map and visibility baseline

A3.3 Identity and Control-Plane Analysis

Objective: Establish the investigative pivot

- Review authentication logs and session activity
- Analyze token issuance and delegation chains
- Examine API calls and automation events
- Identify service account usage and privilege escalation

Key Questions:

- Who authenticated?
- How was access obtained?
- From where did the activity originate?
- What actions followed authentication?

A.3.4 Initial Timeline Construction (UEM-Lite)

Description: UEM-Lite refers to a simplified, field-expedient version of the Unified Evidence Manifest (UEM) described in §9.3.1.

Objective: Normalize and organize available evidence

Record:

- Timestamp (UTC)
- Identity (user or service principal)
- Action performed
- System or domain involved
- Outcome (success, failure, partial)

Note: Initial timelines may be incomplete and should be refined iteratively.

A3.5 Telemetry Correlation

Objective: Connect activity across domains

- Correlate identity events with cloud and control-plane logs
- Align network flows with API and system activity
- Map edge and OT gateway interactions where applicable

Focus Areas:

- Common identities across systems
- Temporal alignment of events
- Resource and system relationships

A.3.6 Visibility and Gap Assessment

Objective: Identify investigative blind spots

For each domain:

- Visible (full telemetry available)
- Partially visible (limited or provider-controlled telemetry)
- Not visible (no accessible telemetry)

Key Questions:

- What evidence is missing?
- What data would confirm or refute current hypotheses?
- Which teams or providers control missing telemetry?

A.3.7 Hypothesis Development

Objective: Construct and test explanations of observed activity

- Identify likely initial access vectors
- Map potential lateral or cross-domain movement
- Define affected systems and targets

Each hypothesis should include:

- Supporting evidence
- Alternative explanations
- Confidence level
- Required follow-up actions

A.3.8 Hybrid Intelligence Use (If Applicable)

Objective: Assist analysis without compromising integrity

Permitted uses:

- Event clustering
- Pattern identification

- Timeline suggestion

Constraints:

- AI outputs are not authoritative evidence
- All findings must be validated against primary telemetry
- Record model inputs, outputs, and validation steps (see §9.5.1 documentation requirements for format and content)

A.3.9 Iterative Refinement

Objective: Continuously improve reconstruction accuracy

- Revisit telemetry as new data becomes available
- Refine timelines and correlations
- Update or discard hypotheses as necessary

Note: CIFM investigations are inherently non-linear and iterative.

A.3.10 Narrative Reconstruction

Objective: Produce a defensible investigative account

- Document sequence of events
- Identify affected systems and domains
- Include confidence levels and known gaps
- Clearly distinguish observed facts from inferred conclusions

A.3.11 Attribution Preparation

Objective: Enable downstream analytical frameworks

Provide:

- Validated timeline
- Normalized evidence (UEM or equivalent)
- Confidence assessments
- Documentation of visibility constraints

Note: CIFM supports, but does not perform, attribution analysis.

A.4 Operational Considerations

The following conditions are expected and do not represent failure states within CIFM:

- Incomplete or inconsistent telemetry
- The need to revisit earlier assumptions
- Cross-domain dependencies requiring coordination
- Time pressure and evolving evidence availability
- Ephemeral workload termination before imaging — pivot to control-plane and orchestration telemetry (see Section 14)

These conditions are explicitly accounted for within the CIFM approach.

A.5 Core Principles (Quick Reference)

- Identity establishes investigative direction
- Telemetry provides primary evidence
- Correlation reveals relationships across domains
- Human investigators retain authority over conclusions
- Investigations are iterative and non-linear; conclusions must be continuously re-evaluated as new evidence emerges
- Ephemeral workloads are reconstructed, not recovered

A.6 Summary

This field guide operationalizes CIFM for real-world use, providing investigators with a structured yet flexible approach to reconstructing incidents across converged infrastructure environments. It is intended to complement the full CIFM model and support consistent investigative practice under real-world conditions.

Appendix B — Applying CIFM to AI-Driven Operational Incidents

Purpose and Scope

This appendix defines how CIFM applies to incidents in which AI systems, autonomous agents, retrieval-augmented generation (RAG) pipelines, model-connected tools, or AI-connected workflows act as one or more of the following:

- the initiating mechanism of an incident
- the propagation vector
- the decision-layer amplifier
- the authority or workflow intermediary; or
- the investigative risk surface

AI-driven incidents do not require a separate forensic doctrine. They differ from traditional cyber incidents primarily in operational velocity, delegated authority surface, identity usage, decision-layer coupling, provider opacity, and ephemeral execution patterns. CIFM already contains the investigative machinery required to reconstruct these events; this appendix makes that application explicit.

This appendix does not define AI governance policy, AI ethics controls, model-development standards, or enterprise AI strategy. It addresses investigative reconstruction when AI systems, agents, model outputs, retrieval pipelines, tool invocations, or AI-connected workflows become part of the evidence chain.

B.1 AI Systems as Converged Infrastructure Components

AI systems participating in operational workflows should be treated as first-class investigative components within converged infrastructure. Where they invoke tools, initiate workflows, generate decisions, or act through delegated authority, they should be analyzed as actor-adjacent control surfaces rather than presumed independent actors.

Relevant AI-linked components include:

- LLMs and model-serving endpoints
- autonomous agents and tool-invocation chains
- RAG pipelines and vector-store retrieval paths
- workflow orchestrators, such as Airflow, Step Functions, Argo, CI/CD runners, or equivalent automation systems
- MCP servers, plugins, connectors, and external tool bridges
- AI-connected business systems, including CRM, ERP, ticketing, financial, HR, legal, customer support, and DevOps platforms

These systems operate through identity, delegated authority, API actions, approval paths, data retrieval, and control-plane events. They therefore fall within CIFM's identity-centric investigative posture.

The central question is not whether the AI “decided” to act. The central question is what authority path allowed an AI output, tool invocation, workflow step, or automation chain to produce operational effect.

B.2 Evidence Sources for AI-Driven Incidents

AI-related evidence should be preserved and normalized into the Unified Evidence Manifest (UEM) where relevant. Evidence sources may include:

- prompts, inputs, and session context
- model outputs and tool-call arguments
- tool-call results and downstream API responses
- model version, configuration, policy state, and system/developer instructions where available
- RAG retrieval sources, vector-store query results, document versions, and retrieval rankings
- API actions triggered by AI systems or AI-connected tools
- delegated identities, temporary credentials, service accounts, and approval paths
- downstream workflow actions and business-system effects
- orchestration logs for agentic, multi-step, or tool-mediated workflows
- human approval, denial, override, escalation, or bypass records

These artifacts may constitute primary evidence when preserved from authoritative systems of record. Where they are exported, summarized, transformed, screen-captured, reconstructed, or user-provided, their provenance and integrity must be documented before they are used to support conclusions.

AI-related artifacts must be evaluated according to provenance, integrity, and system-of-record status. Server-side logs, signed audit records, provider telemetry, cryptographically preserved workflow traces, and original API records carry greater evidentiary weight than user-provided excerpts, AI-generated summaries, screenshots, or reconstructed transcripts.

Prompts alone are not sufficient to establish causality. The relevant evidentiary chain is:

input → model/retrieval context → output → tool/action path → identity authority → downstream effect → corroborating telemetry

B.3 Mapping AI-Crisis Symptoms to CIFM Phases

AI-driven incidents often present as business, operational, reputational, or decision-integrity failures before they present as technical failures. The following table maps common AI-crisis symptoms to CIFM’s investigative phases. Because CIFM is iterative, these mappings identify primary investigative emphasis rather than fixed linear sequence.

AI symptom	Primary CIFM phases	Investigative focus
Incorrect or harmful AI decision	Phase 1 — Infrastructure Context Assessment; Phase 4 — Behavioral Reconstruction; Phase 6 — Narrative Reconstruction	Identify affected workflows, reconstruct the decision chain, distinguish model output from human or business action, and document downstream effect.
Data leakage via AI interface	Phase 2 — Identity & Control-Plane Analysis; Phase 3 — Telemetry Fabric Correlation; Phase 4 — Behavioral Reconstruction	Determine identity, retrieval source, access path, output exposure, recipient, and whether access was authorized or excessive.
Autonomous or semi-autonomous unauthorized action	Phase 2 — Identity & Control-Plane Analysis; Phase 3 — Telemetry Fabric Correlation; Phase 4 — Behavioral Reconstruction	Reconstruct delegated identity, tool call, API action, object target, authorization scope, approval state, and resulting change.
Unpredictable model behavior	Phase 3 — Telemetry Fabric Correlation; Phase 4 — Behavioral Reconstruction; Phase 6 — Narrative Reconstruction	Correlate inputs, model/configuration state, retrieval context, outputs, workflow effects, and confidence limits.
Prompt injection or retrieval manipulation	Phase 2 — Identity & Control-Plane Analysis; Phase 3 — Telemetry Fabric Correlation; Phase 4 — Behavioral Reconstruction	Identify injected content, retrieval path, authority boundary crossed, tool invocation, and compensating evidence.
Reputational or trust collapse	Phase 4 — Behavioral Reconstruction; Phase 6 — Narrative Reconstruction; Phase 7 — Attribution & Evidentiary Evaluation	Produce a defensible timeline, separate observed facts from interpretations, document public/business impact, and prepare legal or executive handoff.

B.4 Identity and Control-Plane as the Investigative Pivot

AI-driven incidents frequently occur through legitimate identities performing authorized actions at machine speed. CIFM requires investigators to anchor reconstruction on:

- actor identity or identity proxy
- AI role in the event
- delegation chain
- temporary credential issuance
- authorization scope
- tool permission boundary
- approval or override state
- object targets

- control-plane events
- downstream system of record

This identity-first posture is essential because AI-orchestrated activity often appears as valid API activity, normal workflow execution, or authorized business-system interaction rather than as an obvious anomaly.

Investigators should ask:

- What identity, service account, role, token, or identity proxy was used?
- What tool, connector, plugin, MCP server, or workflow bridge translated AI output into action?
- Was human approval required?
- Was human approval observed?
- Was the action auto-approved, denied, bypassed, escalated, or never gated?
- Which system of record committed the resulting action?
- Which telemetry independently corroborates the chain?

B.5 Ephemeral Workload Handling for AI-Orchestrated Actions

AI-driven incidents frequently execute through transient infrastructure, including:

- serverless functions
- short-lived containers
- CI/CD runners
- batch jobs
- transient compute bursts
- temporary tool-execution environments
- dynamically spawned agent subprocesses

These workloads may terminate before containment, preservation, or traditional acquisition can occur.

CIFM distinguishes:

Declared State — what the environment was intended to run

Observed State — what preserved telemetry proves actually ran

Initiating Mechanism — the identity, process, workload, tool, connector, or automation path that triggered execution

Origin Chain Confidence — how well the initiating path can be corroborated

Reconstruction, not recovery, is the required posture. Investigators should reconstruct behavior from preserved control-plane, orchestration, identity, runtime, network, registry, and downstream system telemetry. The absence of a recoverable container, function instance, or transient host image is not itself a failure condition; the confidence impact depends on what surrounding telemetry was preserved.

B.6 Hybrid Intelligence Constraints for AI-Assisted Investigation

CIFM's HITL tiers apply with special force to AI-driven incidents. Investigators must prevent AI-assisted investigation from contaminating the evidentiary record.

Tier 1 — Automated Assistance

AI may cluster telemetry, summarize large event sets, generate candidate correlations, or identify repetitive patterns. All outputs must be labeled as suggestions and traceable to UEM entries.

Tier 2 — Hybrid Analysis

AI may propose hypotheses or candidate timelines. Human investigators must validate each claim against primary evidence. Verification steps must be logged, including rejected hypotheses.

Tier 3 — Human-Only Validation

Final narrative reconstruction, evidentiary evaluation, confidence assignment, and attribution handoff decisions must be performed by humans. AI outputs may inform the process but cannot constitute sole evidence.

Investigators must avoid using one AI system to validate another AI system's outputs without independent primary evidence. AI-assisted clustering, summarization, and hypothesis generation may accelerate analysis, but they cannot establish evidentiary truth.

B.7 Visibility Gaps and Confidence Accounting

AI-driven incidents often involve provider-side opacity, incomplete retrieval logs, unavailable model internals, missing orchestration traces, or non-reproducible model outputs. CIFM requires:

- explicit classification of visibility domains as Visible, Partially Visible, or Dark
- confidence assessment tied to evidence completeness, cross-domain corroboration, and visibility gaps
- documentation of unobservable, provider-restricted, or non-reproducible surfaces
- identification of compensating evidence where direct evidence is unavailable
- preservation of uncertainty in the final narrative

Visibility gaps are first-class artifacts, not investigative failures. Reconstruction claims must not exceed the evidentiary scope of preserved telemetry.

When model internals, retrieval state, or provider-side execution traces are unavailable, investigators should explicitly document:

- what cannot be observed
- who controls the missing telemetry
- whether legal, contractual, or provider escalation is possible
- how the missing evidence affects confidence
- which alternative hypotheses remain viable

B.8 Applying CIFM to AI-Orchestrated Attacks — GTG-1002 Case Study

The GTG-1002 campaign publicly reported by Anthropic in 2025 provides a useful stress test for CIFM's application to AI-orchestrated operational activity. The campaign is used here as a public case study for AI-orchestrated operational tempo and delegated tool use, not as an attribution finding independently made by CIFM.

Public reporting on GTG-1002 describes:

- AI performing a substantial portion of tactical operations, reportedly 80–90% of campaign activity
- high-volume, machine-speed activity at physically impossible request rates
- multi-target reconnaissance and exploitation
- use of Claude Code and tool-connected workflows
- activity involving roughly thirty target entities
- identity-driven API and tool activity
- partial human involvement at selected decision points

CIFM's application:

Phase 1: Establish infrastructure context, visibility boundaries, affected organizations, tool chains, and AI-connected systems.

Phase 2: Pivot through service accounts, delegated identities, temporary credentials, API authorities, and MCP/tool connections.

Phase 3: Normalize high-volume API actions, tool invocations, and telemetry into UEM timelines.

Section 14: Reconstruct ephemeral workloads or transient tool-execution environments from surrounding telemetry.

Phase 5: Use HITL Tier 2 methods to cluster machine-speed activity while requiring human validation against primary evidence.

Phase 6: Produce a narrative reconstruction with confidence annotations and visibility gaps.

Phase 7: Prepare an attribution handoff package with bounded confidence, without treating CIFM itself as the attribution framework.

GTG-1002 validates CIFM's design assumptions: identity, automation, control-plane activity, high-volume telemetry, AI-assisted execution, and provider opacity can converge into a single investigative surface.

B.9 Executive and Legal Handoff

AI-driven incidents require a defensible narrative that distinguishes:

- observed facts
- corroborated sequences
- inferred conclusions
- AI-generated outputs
- human-validated findings
- visibility gaps
- confidence levels
- unresolved alternative explanations

CIFM's narrative reconstruction phase produces the evidentiary package required for:

- executive briefings
- regulatory inquiries
- legal proceedings
- insurance review
- incident postmortems
- attribution frameworks such as FACT

CIFM-AI reconstruction does not attribute AI-driven activity to a real-world actor by itself. It produces the validated timeline, identity/control-plane evidence, visibility gaps, normalized evidence, and confidence assessments required by downstream attribution frameworks.

B.10 Summary

AI-driven incidents are not a new category of forensic failure. They are identity-driven, automation-accelerated, telemetry-distributed incidents in which AI systems may serve as decision-layer amplifiers, actor-adjacent control surfaces, workflow intermediaries, evidence sources, or investigative risks.

They require:

- identity-centric reconstruction
- control-plane analysis
- AI evidence preservation
- ephemeral workload handling
- hybrid intelligence governance
- visibility-bounded confidence
- normalized evidence representation
- human-validated narrative reconstruction

CIFM already provides the investigative machinery. This appendix defines how to apply it when AI systems become part of the evidence chain.

Appendix B-1 — GTG-1002 Walkthrough Using CIFM

This walkthrough demonstrates how CIFM reconstructs an AI-orchestrated campaign in which:

- a substantial portion of tactical operations is executed by an AI system
- activity occurs at high volume and machine speed
- execution may involve transient tooling, agent processes, or ephemeral compute
- identities and API actions may appear legitimate
- detection and response windows may collapse to minutes
- provider-side visibility may be incomplete

GTG-1002 is treated here as a public stress test for CIFM's reconstruction logic.

Phase 1 — Infrastructure Context Assessment

Objective: Establish the operational environment the AI-orchestrated activity operated within.

GTG-1002 application:

- Identify all cloud regions, accounts, tenants, services, repositories, and business systems targeted.
- Determine which AI-connected systems, tools, connectors, MCP servers, or agent frameworks had access to internal APIs.
- Document the workflows the AI-connected system could influence, including CI/CD, ticketing, CRM, DevOps tooling, identity platforms, and data repositories.
- Classify visibility domains as Visible, Partially Visible, or Dark.
- Identify provider-restricted evidence surfaces

Outcome: A bounded scope of the infrastructure, identity, tool, workflow, and visibility surfaces the AI-orchestrated activity could reach.

Phase 2 — Identity and Control-Plane Analysis

Objective: Determine which identities, roles, tokens, or service accounts enabled action.

GTG-1002 application:

- Trace API actions to service accounts, delegated identities, user accounts, or identity proxies
- Identify temporary credentials issued during the campaign
- Map delegation chains, such as: AI → tool → MCP server → service account → cloud API
- Determine whether activity occurred under adversarial direction, legitimate workflow triggers, compromised credentials, excessive agency, or misconfigured authority boundaries
- Identify approval gates and whether they were followed, bypassed, or absent

Outcome: A clear identity graph showing the authority paths used to produce operational effect.

Phase 3 — Telemetry Fabric Correlation

Objective: Normalize high-volume telemetry into a coherent timeline.

GTG-1002 application:

- Convert high-volume API calls, tool invocations, authentication events, and workflow actions into UEM entries
- Correlate cloud logs, identity provider logs, network flow logs, application logs, tool execution logs, and downstream system records
- Identify patterns of reconnaissance, enumeration, exploitation, credential access, privilege escalation, staging, and exfiltration
- Detect divergence between declared workflows and observed behavior
- Mark events where source telemetry is incomplete, provider-restricted, or unavailable

Outcome: Machine-speed activity becomes a human-legible, evidence-anchored timeline.

Phase 4 — Behavioral Reconstruction

Objective: Determine what the AI-orchestrated activity actually did.

GTG-1002 application:

- Reconstruct reconnaissance sequences, such as user enumeration, bucket listing, repository enumeration, endpoint discovery, or database queries
- Identify exploitation actions, including privilege escalation, exploitation of misconfigured IAM, abuse of exposed services, or tool-mediated access
- Reconstruct credential harvesting, data access, staging, and exfiltration preparation where telemetry supports those conclusions
- Compare observed behavior to expected agentic workflows
- Identify benign, authorized, or non-adversarial explanations that could account for the same evidence

Outcome: A defensible sequence of actions, bounded by preserved evidence and alternative hypotheses.

Phase 5 — Hybrid Intelligence Analysis (HITL Tier 2)

Objective: Use AI to assist clustering and hypothesis generation while preventing contamination of the investigative record.

GTG-1002 application:

- AI may cluster large volumes of similar API calls into behavioral groups
- AI may suggest candidate timelines or identify repeated execution patterns
- Human investigators validate each cluster against UEM entries and primary telemetry
- Human investigators confirm, reject, or modify AI-generated hypotheses
- No AI-generated hypothesis is accepted without primary-evidence validation

Outcome: Accelerated analysis without epistemic compromise.

Phase 6 — Narrative Reconstruction with Visibility and Confidence Accounting

Objective: Produce a defensible investigative narrative that documents what can and cannot be proven.

GTG-1002 application:

- Construct a timeline showing AI-orchestrated reconnaissance, exploitation, credential access, data staging, and exfiltration where supported by evidence
- Document identity paths, tool chains, ephemeral workloads, and control-plane actions
- Identify Dark or Partially Visible domains, such as provider-side model internals, incomplete retrieval logs, missing tool telemetry, or unavailable orchestration traces
- Assign confidence levels to each reconstructed sequence
- Distinguish observed facts, corroborated sequences, inferred conclusions, and unresolved alternatives

Outcome: A narrative that is honest, bounded, and defensible for operational, executive, legal, and regulatory audiences.

Phase 7 — Attribution and Evidentiary Evaluation Handoff

Objective: Prepare the evidence package for downstream attribution or legal analysis without allowing CIFM to exceed its reconstruction boundary.

GTG-1002 application:

- Preserve the validated timeline, UEM records, source evidence references, confidence levels, and visibility gaps
- Document actor-relevant evidence without making unsupported actor claims
- Provide the evidentiary package to attribution frameworks such as FACT
- Preserve alternative explanations and confidence constraints

Outcome: A complete, defensible reconstruction package suitable for downstream attribution analysis, legal review, or executive decision-making.

Appendix B-2 — CIFM-AI Evidence Schema (UEM Extensions)

This schema defines optional evidence fields used to reconstruct AI-driven incidents. These fields extend the Unified Evidence Manifest (UEM) without altering its core structure.

B-2.1 Core UEM Fields (Unchanged)

- Event Time
- Infrastructure Domain
- CIFM Layer
- Actor Identity
- Action Verb
- Object Target
- Outcome

- Evidence Hash

These remain the backbone of all CIFM investigations.

B-2.2 AI-Specific Evidence Extensions

1. Prompt and Input Context

- Prompt / Input Reference
- Full Prompt Text, where available and lawful to retain
- System Instructions Reference
- Developer Instructions Reference
- Session Identifier
- Session Metadata
- Input Source: user | system | tool | retrieved content | adversarial injection | automated workflow | unknown
- Prompt Injection Indicator: none | suspected | confirmed | unknown
- Prompt Preservation Status: original | hashed | redacted | summarized | unavailable

2. Model Output and Tool Invocation

- Raw Model Output Reference
- Output Preservation Status: original | hashed | redacted | summarized | unavailable
- Output Classification: benign | harmful | ambiguous | policy-modified | unknown
- Tool / Function Invoked
- Tool-Call Arguments
- Tool-Call Results
- Tool Permission Boundary
- Policy Decision Point
- Policy Decision Outcome: allowed | blocked | modified | escalated | unknown

3. Model Metadata

- AI System Identifier
- Model / Engine Name
- Model / Engine Version
- Deployment Identifier
- Configuration Parameters
- Guardrail / Policy Version
- Temperature / Top-p Settings, if relevant and available
- Provider-Side Metadata, if available
- Reproducibility Status: reproducible | partially reproducible | non-reproducible | unknown

4. RAG and Retrieval Evidence

- Retrieval Corpus Identifier
- Retrieval Snapshot / Version

- Vector-Store Query Text or Query Reference
- Retrieved Document References
- Retrieved Document Versions
- Retrieval Ranking / Scoring
- Source Repository, Bucket, or Knowledge Base
- Data Classification of Retrieved Content
- Retrieval Preservation Status: original | partial | metadata only | unavailable

5. Agentic Workflow Evidence

- AI Role in Event: initiator | recommender | executor | summarizer | reviewer | intermediary | unknown
- Orchestration Graph / Declared Workflow
- Observed Workflow from Telemetry
- Divergence Points
- Sub-Agent or Tool-Chain Invocations
- Human Approval Required: yes | no | conditional | unknown
- Human Approval Observed: approved | denied | bypassed | not required | unknown
- Approval / Override Logs
- Automation Trigger Source

6. Identity and Delegation Evidence

- Actor Identity or Identity Proxy
- Service Account Used
- Temporary Credentials Issued
- Delegation Chain: AI → tool → identity → API / system
- Authorization Scope
- Object Targets Accessed
- Identity Provider Event Reference
- Session / Token Issuance Reference
- Privilege Boundary Crossed: yes | no | unknown

7. Ephemeral Workload Evidence

- Resource Type: container | function | job | CI runner | transient VM | agent subprocess | other
- Orchestrator / Execution Environment
- Invocation Logs
- Runtime Parameters
- Execution Duration
- Termination Reason
- Runtime Telemetry Sources
- Preservation Status: imaged | logs only | metadata only | unavailable
- Correlated Telemetry Proving Behavior After Workload Destruction
- Origin Chain Confidence: high | medium | low | unknown

8. Downstream System Impact

- Downstream System of Record
- Business-System Actions Triggered
- Data Modified, Exposed, Deleted, or Transmitted
- Workflow Steps Executed
- Human-Approval Paths Bypassed or Followed
- External Recipient / Destination, where applicable
- Operational Impact
- Rollback / Remediation State

9. Confidence and Visibility Metadata

- Visibility Domain Classification: Visible | Partially Visible | Dark
- Confidence Level: High | Medium | Low
- Evidence Gaps
- Provider-Restricted Surfaces
- Alternative Hypotheses Considered
- Confidence Impact
- Analyst Notes

B-2.3 Evidence Integrity Requirements

Traceability

Every AI-related UEM entry must be traceable to a primary source, such as a log, API record, provider audit trail, retrieval trace, identity event, workflow record, or preserved system artifact.

Non-Substitution Rule

AI-generated summaries may not replace primary evidence. They may be retained as analytical artifacts, but conclusions must be grounded in primary telemetry, preserved records, or validated source evidence.

HITL Documentation

All human validation steps must be logged, including accepted, modified, and rejected hypotheses. Validation records should identify the source evidence reviewed, the human reviewer, the conclusion reached, and any unresolved uncertainty.

Provider-Side Opacity Handling

Where model internals, provider telemetry, retrieval state, or tool-execution traces are unavailable, investigators must document the visibility gap and its impact on confidence.

Reproducibility Limits

Where model output cannot be reproduced because of provider constraints, model nondeterminism, missing configuration state, unavailable retrieval snapshots, or incomplete prompt/session preservation, the non-reproducibility must be recorded as a confidence impact.

Evidence Weighting

Server-side logs, signed audit trails, preserved API records, and authoritative workflow records should be weighted more heavily than screenshots, copied text, human recollections, AI-generated summaries, or reconstructed transcripts.

Beyond evidence integrity at the artifact level, CIFM requires a formal evaluation of the collection infrastructure itself when dealing with distributed AI workflows.

B-2.4 Observability Pipeline Treatment

Observability pipelines are not neutral conduits. Collector configurations, processor logic, sampling, redaction, transformation, export routing, and retention settings all determine what is preserved, what is altered, and what is never seen by the investigator. Within CIFM, the telemetry pipeline is an **evidence environment artifact** that must be documented whenever its outputs are used to support reconstruction.

Telemetry-derived UEM entries must include recorded provenance, timestamp context, and explicit notation of any transformation history. Where trace or correlation context fragments across tool, API, or execution boundaries, the fragmentation must be recorded as a visibility gap and reflected in the final confidence score. See Section 9.3.2 for the full formal treatment of operational observability and AI-agent telemetry.

Document Control

- Initial creation: 13 Mar 2026
- Draft v0.1: 13 Mar 2026
- Peer review: 13 Mar 2026
- v0.15 with expanded references: 16 Mar 2026
- v0.16 with structural and architectural enhancements: 16 Mar 2026
- v0.17 with expanded and additional sections: 16 Mar 2026
- v0.18 with expanded sections: 22 Mar 2026
- v0.19 with Claim of Contribution added; sections renumbered: 22 Mar 2026
- v0.20 with Abstract and Introduction refined for consistency with Claim of Contribution: 22 Mar 2026

- v0.21 with updated Section 15 – Expanded Limitations of CIFM: 22 Mar 2026
- v0.22 with added Addendum A - CIFM Incident Response Field Guide: 22 Mar 2026
- v0.23 with updated Sections 1, 5, 9, Appendix A: 23 Mar 2026
- v0.24 with updated Sections 5, 16, Appendix A: 23 Mar 2026
- v0.25 with updated Sections 3, 7, 13, 16: 23 Mar 2026
- v0.26 with updated Section 16: 23 Mar 2026
- v0.27 with updated Appendix A: 23 Mar 2026
- v0.28 with updated Sections 1, 6, 9, 10, 12, 17, Appendix A: 23 Mar 2026
- v0.29 with updated Sections 6, 9: 23 Mar 2026
- v0.30 with updated Section 9: 23 Mar 2026
- v0.31 with updated Section 11: 23 Mar 2026
- v0.32 – Final pre-release draft version: 30 Mar 2026
- v1.0RC – Incorporated reviewer feedback and strengthened Section 14 to clarify CIFM’s complementary relationship to FACT. Published 04 Apr 2026.
- v1.1RC – Added Henriques et al. (2023) to Sections 6 and 13, strengthening CIFM’s relationship to FCA-based IACS evidence-collection infrastructure. Updated References accordingly. 13 Apr 2026.
- v1.2RC – Added Section 14 (Ephemeral Workload Handling), formalizing CIFM’s treatment of transient compute, reconstruction vs. recovery, visibility gaps, and forensic-by-design readiness. Updated UEM, anti-patterns, forensic readiness, cross-references, glossary, and Appendix A accordingly. 02 May 2026.
- v1.2.1RC – Clarified runtime-spawned workloads and undeclared execution paths, distinguishing declared state, observed state, initiating mechanism, and origin chain confidence. Expanded the UEM Ephemeral Workload Extension and clarified confidence impacts where initiating mechanisms cannot be corroborated. 03 May 2026.
- v1.3RC – Added Appendix B (Applying CIFM to AI-Driven Operational Incidents), extending CIFM to AI-linked operational events with AI-specific UEM guidance, HITL constraints, provider-opacity handling, GTG-1002 application, and executive/legal handoff. Updated title metadata, Sections 6, 9.3.1, 13, and 16.5, glossary, and references accordingly. 17 May 2026.
- v1.4RC – Added Section 9.3.2 (Operational Observability and AI-Agent Telemetry), formalizing CIFM’s treatment of AI-agent telemetry, observability artifacts, collector pipelines, execution-boundary context, and timestamp/sequence integrity. Updated Section 6, Section 12, Section 13, Appendix B-2.4, Glossary, and References accordingly. 19 May 2026.

- v1.5RC — Added Section 9.3.3 (Shadow Systems, Shadow AI, and Reconstruction Debt), formalizing CIFM’s treatment of ungoverned systems, shadow AI deployments, orphaned automation, NHI ownership gaps, blast radius drift, and investigative archaeology of ungoverned access. Added Design Principle 8.8 (Shadow Environment Awareness). Extended Section 9.1.1, Section 9.2, Section 12, and Section 13 with shadow environment and NHI investigative guidance. Added glossary entries for Non-Human Identity, Shadow AI, Shadow IT, and Shadow Processing. Added reference and acknowledgment for Niemi (2026). Conceptual framework for shadow environment sourced from Niemi, C. (2026), *Only the Shadow Knows*. June 2026. Added future work item for developing practitioner implementation worksheets and limited-scope training labs for the Visibility & Trust Boundary Matrix, Minimum Viable CIFM implementation, NHI/token inventory, and shadow environment assessment.